RAPPORT DE PROJET

Projet Patch Management

Système de gestion des mises à jour Windows en PowerShell

Audit des correctifs d'un parc par PowerShell Remoting (WinRM)

Module : **Sécurité des systèmes**

Enseignant : **Salim Benayoune**

Réalisé par

DOSSOU Sam

Cycle ingénieur ING2, EFREI Paris

Dépôt GitHub (privé)

https://github.com/Dkls7777/ProjetGestionDesMaj

Vidéo de démonstration (≈ 15 min)

[lien à ajouter après l'enregistrement]

Année universitaire 2026-2027 | Remise : octobre 2026

Sommaire

1. Introduction 3
1.1 Contexte et objectif 3
1.2 Périmètre réalisé 3
1.3 Livrables 3
2. Architecture de la solution 4
2.1 Environnement de test 4
2.2 Chaîne de traitement 4
2.3 Organisation du dépôt 5
3. Préparation de l'environnement (partie 1) 6
3.1 Mise en place du lab 6
3.2 Connectivité 7
3.3 Fichier computers.txt et script de disponibilité 8
3.4 Activation de WinRM et sessions distantes 8
3.5 Réponses aux questions de la partie 1 9
4. Fonctionnalités réalisées 11
4.1 Inventaire du parc (partie 2) 11
4.2 Inventaire des correctifs (partie 3) 12
4.3 Contrôle de conformité (partie 4) 12
4.4 Rapport de sécurité (partie 6) 14
4.5 Notification (partie 7) 15
5. Sécurisation de la solution (partie 8) 19
5.1 Risques liés à WinRM 19
5.2 Utilisateurs autorisés à ouvrir une session distante 19
5.3 Compte de service à moindre privilège 20
5.4 Just Enough Administration (JEA) 20
5.5 Accès aux fichiers produits 23
5.6 Règles de pare-feu WinRM 23
5.7 Mode d'authentification 24
5.8 Conservation des rapports et des journaux 24
6. Choix techniques 27
7. Tests effectués et résultats 28
8. Difficultés rencontrées 29
8.1 La machine virtuelle ne démarrait pas 29
8.2 WinRM bloqué quelques heures après sa mise en service 29
8.3 Une date de dernier démarrage inattendue 30
8.4 Saturation du disque de l'hôte 30
8.5 Le moindre privilège ne se résume pas à retirer des droits 31
8.6 Enseignements 31
9. Limites et perspectives 32
9.1 Limites de la solution 32
9.2 Perspectives 32
10. Conclusion 33

1. Introduction

1.1 Contexte et objectif

Un poste Windows qui ne reçoit pas ses correctifs de sécurité est un point faible du système d'information : une vulnérabilité publiée et non corrigée peut servir de porte d'entrée, puis de point de départ pour atteindre d'autres machines. Le Patch Management regroupe les activités qui permettent de savoir, à tout moment, quels postes sont à jour et lesquels ne le sont pas.

L'objectif de ce projet est de concevoir, en PowerShell, une solution simplifiée d'audit des correctifs d'un parc Windows. Depuis un poste d'administration central, elle lit un inventaire, interroge chaque poste à distance par PowerShell Remoting (WinRM), compare les correctifs installés à une liste de correctifs obligatoires, produit un rapport, journalise son exécution et prévient l'administrateur en cas d'anomalie.

1.2 Périmètre réalisé

Toutes les parties du sujet ont été traitées. Le sujet passe de la partie 4 à la partie 6, il ne contient pas de partie 5.

Partie du sujet	Réalisation	Section du rapport
1. Préparation de l'environnement	Lab VirtualBox, WinRM, session distante, 7 questions	3
2. Inventaire du parc	`02-Inventaire-Parc.ps1`, `Inventory.csv`	4.1
3. Inventaire des correctifs	`03-Inventaire-Correctifs.ps1`, `PatchesInventory.csv`	4.2
4. Contrôle de conformité	`04-Controle-Conformite.ps1`, `ComplianceReport.csv`	4.3
6. Rapport de sécurité	`PatchManager.ps1`, rapport CSV et HTML, journal	4.4
7. Notification	Envoi d'un mail en cas d'anomalie	4.5
8. Sécurisation	Les 8 points, dont JEA et le contrôle d'intégrité mis en œuvre	5

1.3 Livrables

- Code source et dépôt GitHub privé : https://github.com/Dkls7777/ProjetGestionDesMaj
- Le présent rapport.
- Une vidéo de démonstration d'environ 15 minutes.

Le dépôt contient aussi un journal de bord (`journal.md`), qui retrace chaque étape, chaque choix et chaque difficulté, ainsi que 103 captures d'écran indexées (`captures/INDEX.md`). Dans ce rapport, la mention « capture 042 » renvoie au fichier de ce numéro dans le dossier `captures/` du dépôt.

2. Architecture de la solution

2.1 Environnement de test

Le sujet autorise une infrastructure réduite. Le lab comporte un poste d'administration, un poste supervisé réel et un poste fictif qui sert à tester le cas d'une machine injoignable.

Machine	Rôle	Système	Adresse
DKLS777	Poste d'administration	Hôte Windows 11	192.168.56.1
PC01	Poste supervisé	VM VirtualBox, Windows 11 Entreprise (évaluation), 4 Go de RAM, 2 processeurs	192.168.56.102
PC03	Poste fictif	Aucune machine derrière cette adresse	192.168.56.150

Les deux machines communiquent par un réseau privé hôte VirtualBox (192.168.56.0/24), indépendant du réseau Wi-Fi. PC01 dispose d'une seconde interface en NAT pour l'accès à Internet.

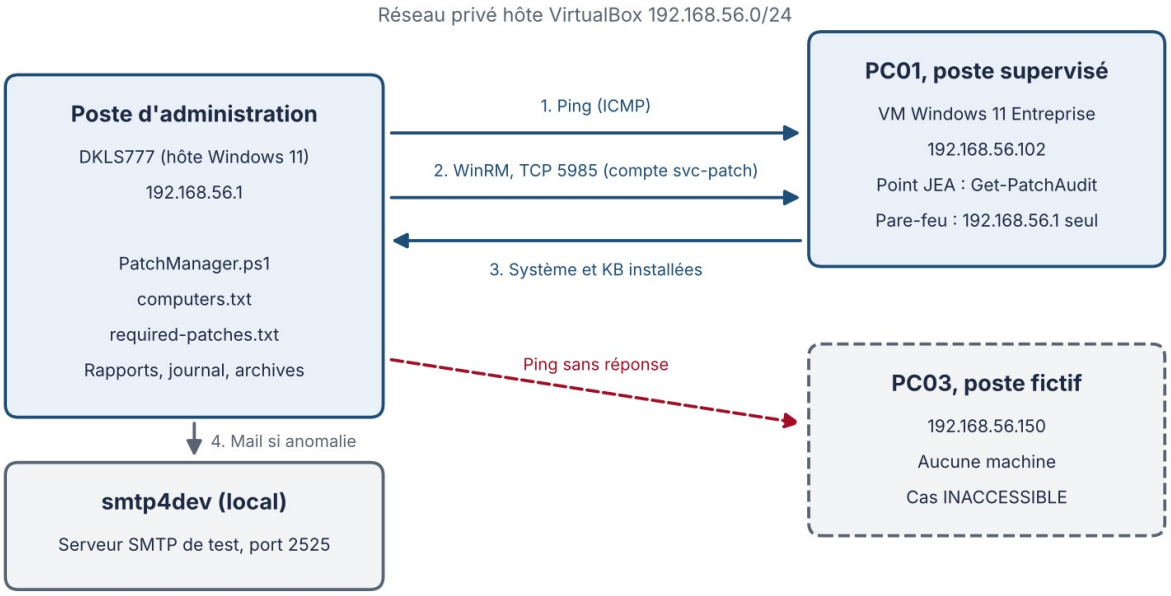


Figure 1 : *Architecture du lab et flux d'un audit*

2.2 Chaîne de traitement

Le script principal réalise un audit complet en une seule passe.

- Lecture de `computers.txt` (une ligne `NOM;ADRESSE_IP` par poste) et de `required-patches.txt` (une KB par ligne).
- Test de disponibilité de chaque poste par ping.
- Collecte à distance par WinRM : version de Windows, date du dernier démarrage, état du service Windows Update, liste des KB installées. Un seul appel distant par poste.
- Comparaison des KB installées avec les KB requises, et attribution d'un état : CONFORME, NON CONFORME ou INACCESSIBLE.
- Production du rapport en CSV et en HTML, avec une synthèse globale et la liste des postes à traiter.
- Archivage daté des rapports et calcul de leur empreinte SHA-256.
- Écriture du journal `PatchManager.log`.

- Envoi d'un mail à l'administrateur si au moins un poste présente une anomalie.

2.3 Organisation du dépôt

Élément	Contenu
`scripts/PatchManager.ps1`	Script principal : audit, rapport, archivage, journal, notification
`scripts/Commun.ps1`	Fonctions partagées : lecture des fichiers d'entrée, journal, rotation
`scripts/01` à `04`	Un script par partie du sujet (disponibilité, inventaire, correctifs, conformité)
`scripts/jea/Install-JeaPatchAudit.ps1`	Installation du point de connexion JEA sur un poste administré
`scripts/Test-IntegriteRapports.ps1`	Contrôle d'intégrité des rapports archivés
`config/`	Inventaire, correctifs requis, paramètres de notification, jeux de test
`exemples/`	Exemples réels de fichiers produits dans le lab
`captures/`, `journal.md`	Preuves et journal de bord

Les scripts 01 à 04 répondent chacun à une partie du sujet et restent utilisables seuls. `PatchManager.ps1` reprend leur logique pour produire le rapport global avec une seule connexion par poste.

3. Préparation de l'environnement (partie 1)

3.1 Mise en place du lab

PC01 a été créée dans VirtualBox 7.2.8 à partir de l'image d'évaluation de Windows 11 Entreprise, avec l'installation sans assistance, qui crée directement un compte local `admin` protégé par mot de passe (WinRM refuse les comptes sans mot de passe). La VM possède deux interfaces réseau : une en NAT, une sur le réseau privé hôte.

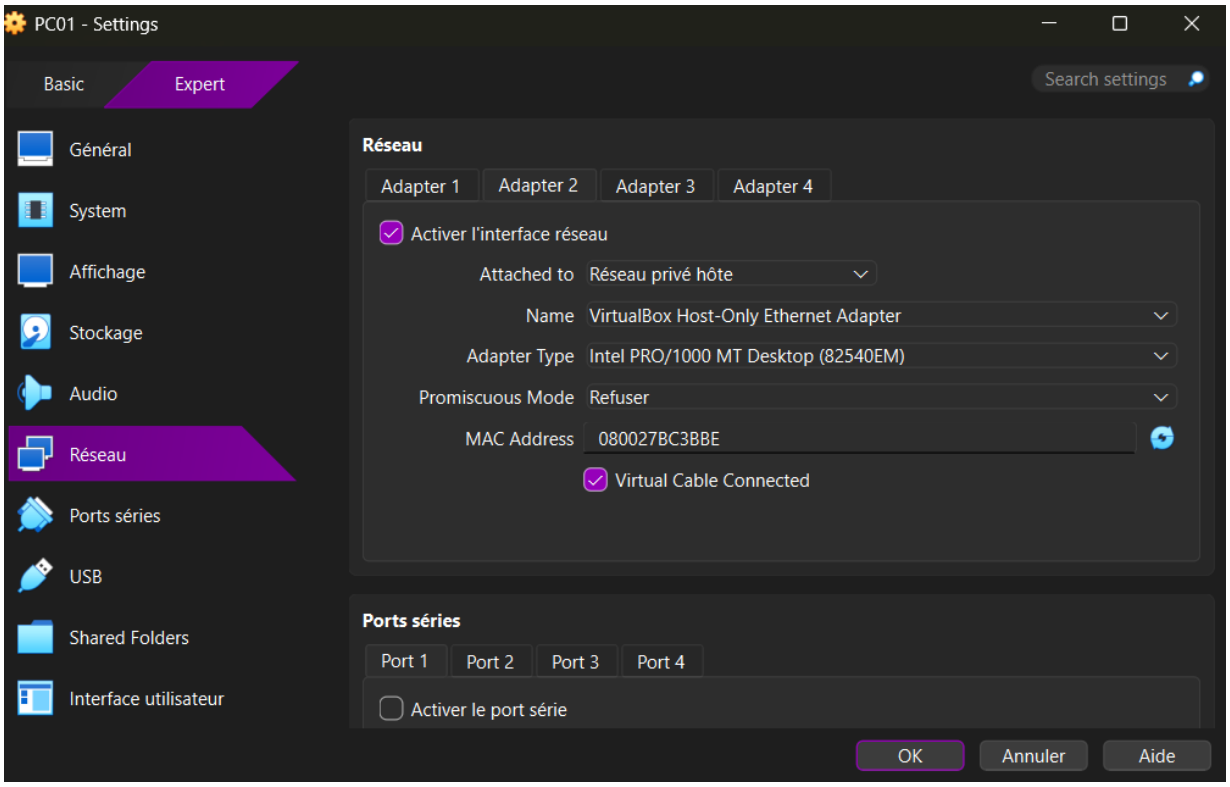


Figure 2 : *Interface 2 de PC01 sur le réseau privé hôte, utilisée pour l'administration distante (capture 021)*

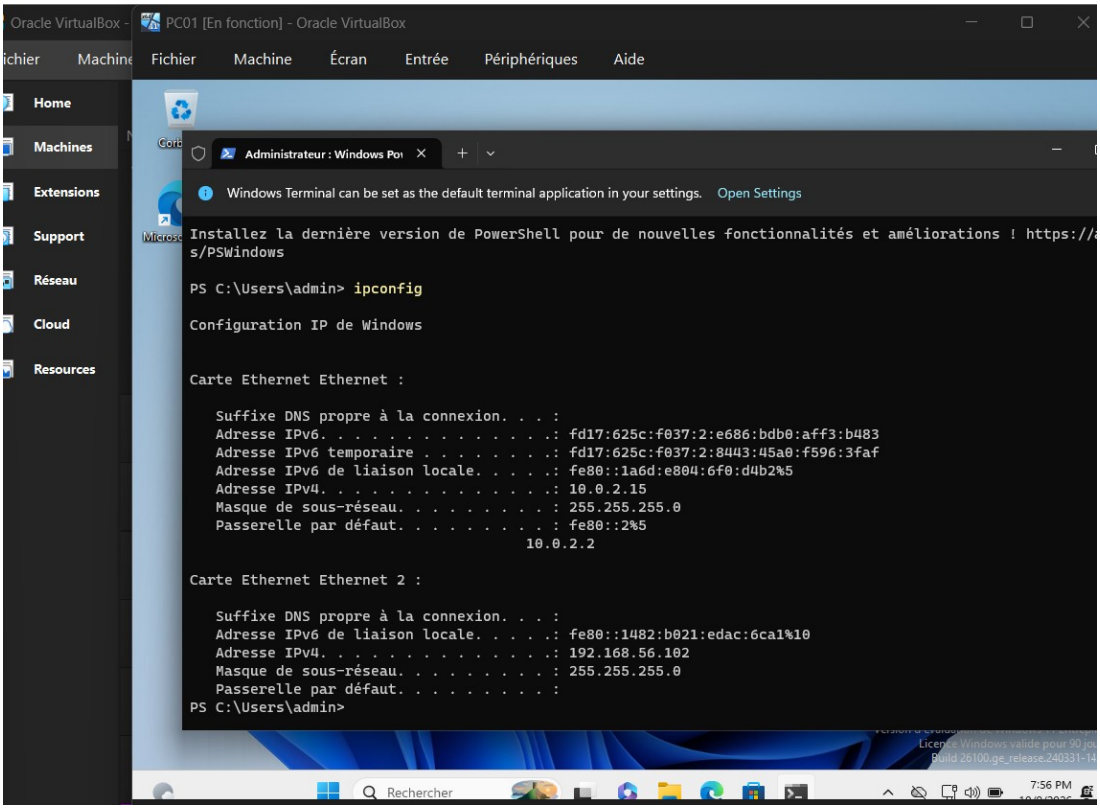


Figure 3 : *Adressage de PC01 : 192.168.56.102 sur le réseau d'administration (capture 022)*

3.2 Connectivité

Le premier test de connectivité depuis le poste d'administration a échoué. La commande `Get-NetConnectionProfile` sur PC01 a montré que l'interface du réseau d'administration était classée en profil Public, le plus restrictif du pare-feu Windows, qui bloque les demandes d'écho ICMP.

```
PS C:\Users\dossa\ProjetGestionDesMaj> Test-Connection -ComputerName 192.168.56.102 -Count 2
Test-Connection : Le test de la connexion à l'ordinateur « 192.168.56.102 » a échoué : Erreur due à des ressources insuffisantes
Au caractère Ligne:1 : 1
+ Test-Connection -ComputerName 192.168.56.102 -Count 2
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ResourceUnavailable: (192.168.56.102:String) [Test-Connection], PingException
    + FullyQualifiedErrorId : TestConnectionException,Microsoft.PowerShell.Commands.TestConnectionCommand

Test-Connection : Le test de la connexion à l'ordinateur « 192.168.56.102 » a échoué : Erreur due à des ressources insuffisantes
Au caractère Ligne:1 : 1
+ Test-Connection -ComputerName 192.168.56.102 -Count 2
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ResourceUnavailable: (192.168.56.102:String) [Test-Connection], PingException
    + FullyQualifiedErrorId : TestConnectionException,Microsoft.PowerShell.Commands.TestConnectionCommand

PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 4 : *Premier test de connectivité en échec : le pare-feu de PC01 bloque l'ICMP (capture 025)*

Après passage de l'interface en profil Privé et activation de la règle d'écho ICMP (`Enable-NetFirewallRule -Name FPS-ICMP4-ERQ-In`), le test réussit.

```
PS C:\Users\dossa\ProjetGestionDesMaj> Test-Connection -ComputerName 192.168.56.102 -Count 2

Source        Destination     IPV4Address      IPV6Address                              Bytes    Time(ms)
------        -----------     -----------      -----------                              -----    --------
DKLS777       192.168.56.102  192.168.56.102   fe80::1482:b021:edac:6ca1%7              32       0
DKLS777       192.168.56.102  192.168.56.102   fe80::1482:b021:edac:6ca1%7              32       0


PS C:\Users\dossa\ProjetGestionDesMaj> hostname
DKLS777
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 5 : *Connectivité validée entre le poste d'administration DKLS777 et PC01 (capture 027)*

3.3 Fichier computers.txt et script de disponibilité

Le fichier `config/computers.txt` contient PC01 et PC03. Le script `01-Test-Parc.ps1` le lit, ignore les lignes vides, les commentaires et les lignes mal formées, puis teste chaque poste avec `Test-Connection -Count 1 -Quiet`, qui renvoie vrai ou faux au lieu de lever une erreur.



Figure 6 : *Résultat du script de disponibilité à partir de computers.txt (capture 028)*

3.4 Activation de WinRM et sessions distantes

Le service WinRM est arrêté par défaut sur un poste client. La commande `Enable-PSRemoting -Force` le démarre, crée l'écouteur HTTP sur le port 5985 et active l'exception de pare-feu.

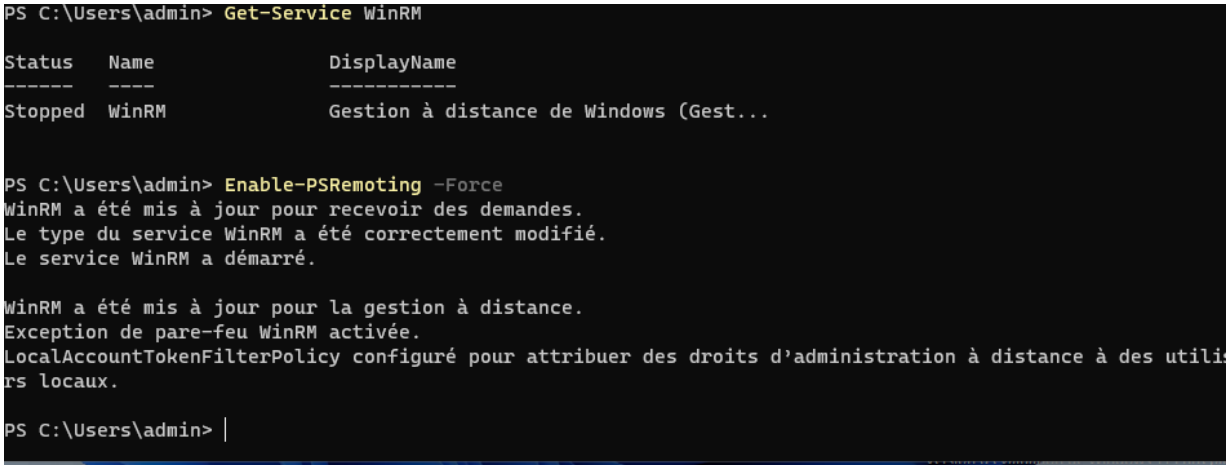


Figure 7 : *Activation de PowerShell Remoting sur PC01 (capture 029)*

Les deux machines n'étant pas dans un domaine Active Directory, l'authentification Kerberos est impossible. PowerShell refuse alors de se connecter tant que la cible n'est pas déclarée dans les TrustedHosts du poste d'administration (`Set-Item WSMan:\localhost\Client\TrustedHosts`). Une fois cette déclaration faite, la session interactive et l'exécution non interactive fonctionnent.

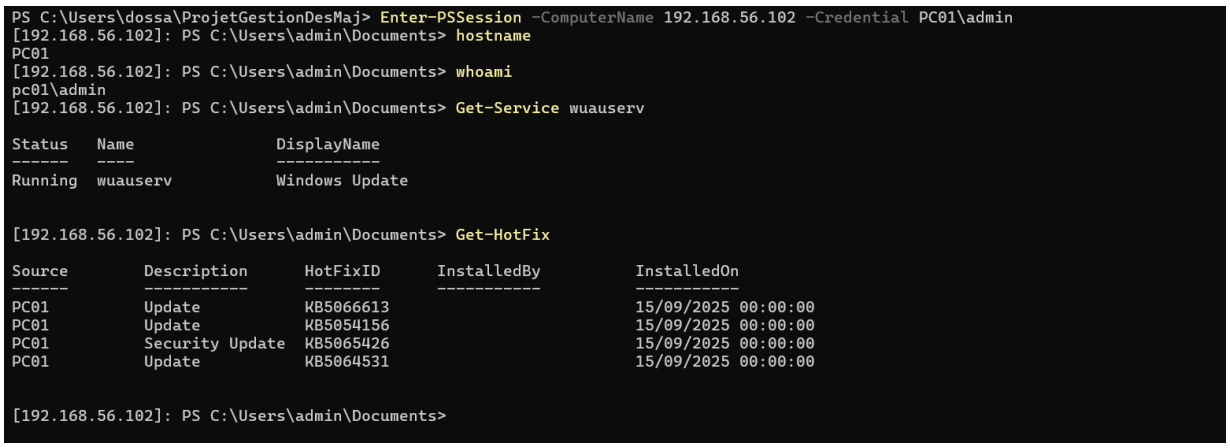


Figure 8 : *Session distante interactive sur PC01 (Enter-PSSession) et exécution de commandes (capture 033)*

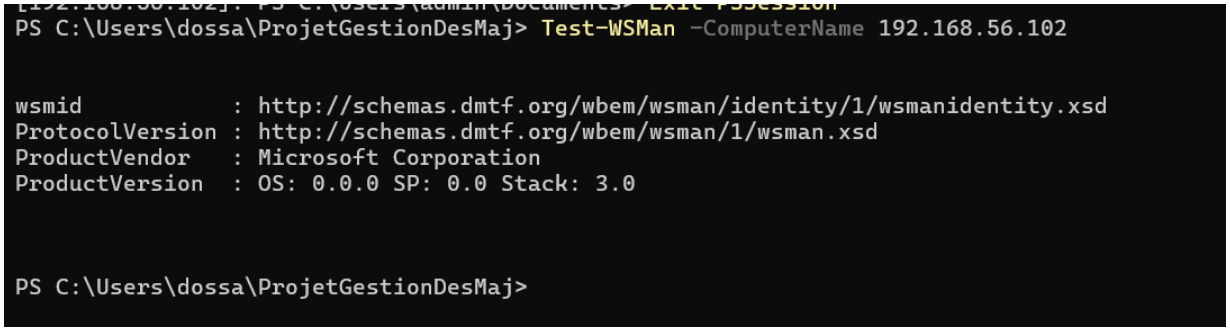


Figure 9 : *Test de l'accès WinRM à PC01 depuis le poste d'administration (Test-WSMan) (capture 034)*



Figure 10 : *Exécution distante non interactive avec Invoke-Command (capture 035)*

3.5 Réponses aux questions de la partie 1

Quel est le rôle de WinRM dans PowerShell Remoting ?

WinRM (Windows Remote Management) est l'implémentation Microsoft du protocole standard WS-Management. C'est le service qui écoute sur le poste distant, authentifie l'appelant et transporte les échanges. PowerShell Remoting s'appuie dessus : quand on lance `Enter-PSSession` ou `Invoke-Command`, la commande est envoyée au service WinRM de la cible, qui démarre un processus PowerShell hôte, l'exécute et renvoie le résultat sous forme d'objets sérialisés. Sans WinRM démarré et configuré sur la cible, aucune commande distante n'aboutit.

Dans le lab : service WinRM arrêté par défaut sur PC01 (capture 029), puis démarré (capture 030).

Quelle commande permet d'activer PowerShell Remoting ?

`Enable-PSRemoting -Force`, dans une console PowerShell lancée en administrateur sur le poste à administrer. Elle démarre le service WinRM et le passe en démarrage automatique, crée un écouteur HTTP, active l'exception de pare-feu et enregistre les configurations de session. Sur un poste hors domaine, elle configure aussi LocalAccountTokenFilterPolicy pour que les comptes locaux administrateurs gardent leurs droits à distance (capture 029).

Quels ports réseau sont utilisés par WinRM ?

- TCP 5985 pour HTTP (utilisé dans le lab).
- TCP 5986 pour HTTPS.

Pourquoi le pare-feu Windows peut-il empêcher une connexion PowerShell distante ?

Le pare-feu Windows bloque par défaut les connexions entrantes qui ne correspondent à aucune règle d'autorisation. Tant que la règle « Gestion à distance de Windows (HTTP-Entrée) » n'est pas activée, le port 5985 est fermé et la connexion échoue même si le service WinRM tourne. Le profil réseau compte aussi : sur un réseau classé Public, les règles sont plus strictes (l'accès WinRM y est limité au sous-réseau local, voire refusé).

Dans le lab, on a observé le même mécanisme avec le ping : la carte du réseau d'administration de PC01 était en profil Public et le pare-feu bloquait l'ICMP (captures 025 et 026). Après passage en profil Privé et activation de la règle, le ping passe (capture 027).

Quelle différence entre Test-Connection et Test-WSMan ?

- `Test-Connection` envoie un ping ICMP. Il vérifie que la machine est joignable au niveau réseau, rien de plus.
- `Test-WSMan` interroge le service WinRM sur le port 5985. Il vérifie que le service écoute et répond, donc que l'administration distante est possible (capture 034).

Les deux résultats sont indépendants : une machine peut répondre au ping avec WinRM arrêté, et à l'inverse avoir WinRM ouvert alors que le pare-feu bloque le ping.

Pourquoi vérifier l'accessibilité d'une machine avant une commande distante ?

- Éviter d'attendre le délai d'expiration de WinRM sur chaque poste éteint, ce qui ralentit fortement l'audit d'un grand parc.
- Distinguer les causes d'échec : poste éteint ou hors réseau, WinRM fermé, ou problème de droits. Le rapport est alors exploitable par l'administrateur.
- Permettre au script de continuer proprement avec les autres postes et de journaliser un état clair (Inaccessible) au lieu d'une erreur brute.

Quels problèmes de sécurité si PowerShell Remoting est activé sans restriction ?

- Exécution de code à distance : tout compte autorisé (ou volé) peut lancer des commandes avec ses privilèges sur le poste.
- Mouvement latéral : un attaquant qui compromet un compte administrateur réutilisé sur plusieurs postes rebondit de machine en machine. En NTLM, le vol du condensat du mot de passe peut suffire (pass-the-hash).
- LocalAccountTokenFilterPolicy rend les comptes locaux administrateurs pleinement utilisables à distance.
- Absence d'authentification du serveur hors Kerberos ou HTTPS : avec NTLM sur HTTP et des TrustedHosts trop larges (par exemple `*`), le client peut envoyer ses identifiants à une machine usurpée.
- Surface d'attaque étendue si le port 5985 est joignable depuis tous les réseaux et non depuis le seul poste d'administration.

Mesures traitées en partie 8 : filtrage du pare-feu par adresse source, compte dédié à moindre privilège, HTTPS ou Kerberos, JEA, journalisation.

4. Fonctionnalités réalisées

4.1 Inventaire du parc (partie 2)

Le script `02-Inventaire-Parc.ps1` collecte, pour chaque poste accessible, les caractéristiques demandées par le sujet. La collecte s'appuie sur `Get-CimInstance` (classes Win32_ComputerSystem, Win32_OperatingSystem, Win32_BIOS, Win32_LogicalDisk), `Get-HotFix` et `Get-Service wuauserv`, exécutés à distance par `Invoke-Command`.

- L'appel distant est placé dans un bloc `try/catch` avec `-ErrorAction Stop` : si un poste est injoignable ou si la commande échoue, le script continue et enregistre l'erreur dans l'inventaire.
- Chaque poste est représenté par un objet PowerShell. Une fonction garantit que toutes les lignes ont les mêmes colonnes, y compris pour les postes inaccessibles, sans quoi l'export CSV perdrait des champs.
- Les identifiants sont passés par un objet `PSCredential` ou demandés à l'exécution. Aucun mot de passe n'est écrit dans un script.

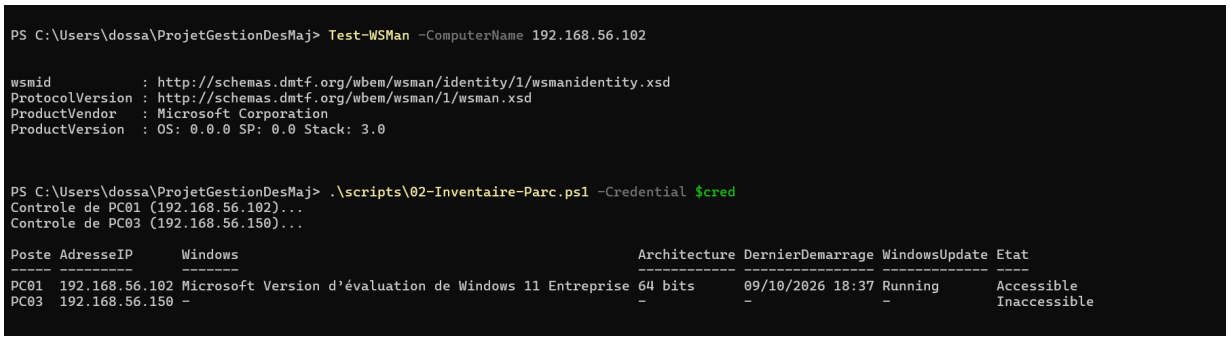


Figure 11 : *Tableau récapitulatif de l'inventaire du parc (capture 042)*

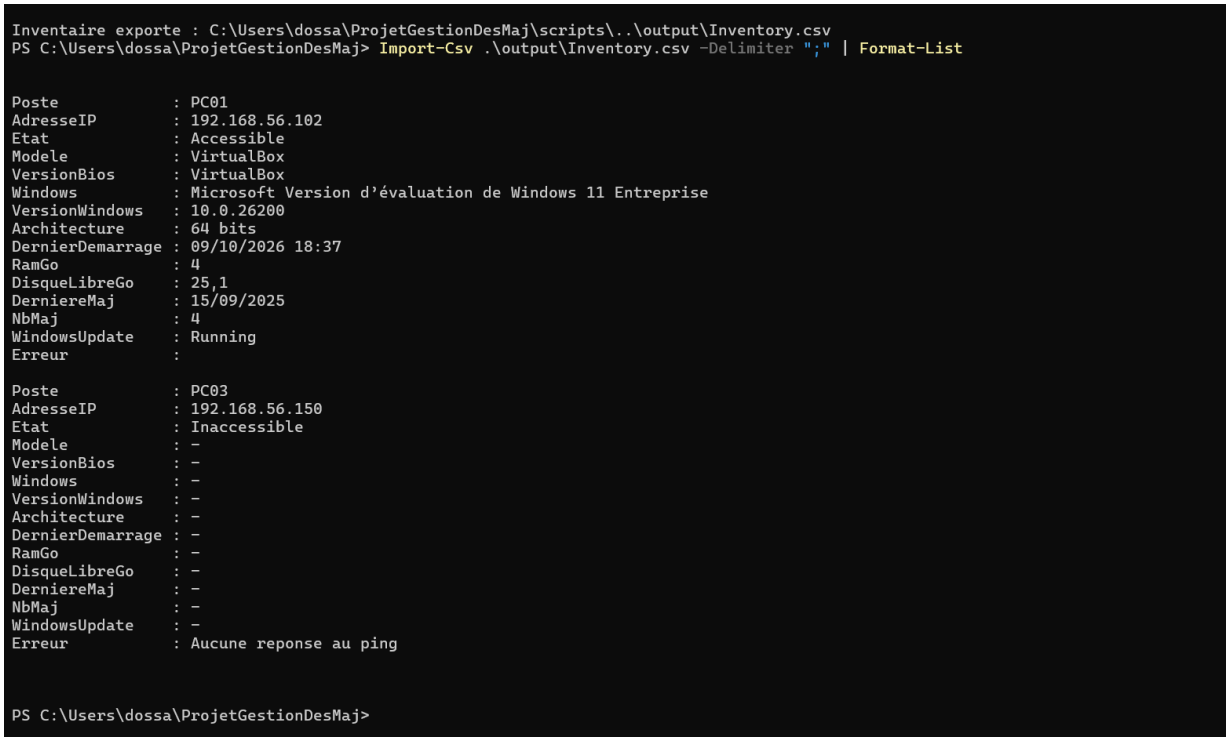


Figure 12 : *Inventaire détaillé exporté dans Inventory.csv (capture 043)*

4.2 Inventaire des correctifs (partie 3)

Sur la machine locale, `Get-HotFix` donne pour chaque correctif son numéro de KB, sa description, sa date d'installation et le compte qui l'a installé, quand l'information est disponible.



Figure 13 : *Correctifs installés sur la machine locale et informations associées (capture 048)*

Le script `03-Inventaire-Correctifs.ps1` récupère ces informations à distance sur chaque poste accessible, ignore les postes injoignables avec un avertissement, trie le résultat par poste puis par date d'installation décroissante, et l'exporte dans `PatchesInventory.csv`. Il affiche ensuite, par machine, le nombre de correctifs, la date du plus récent et son numéro de KB.

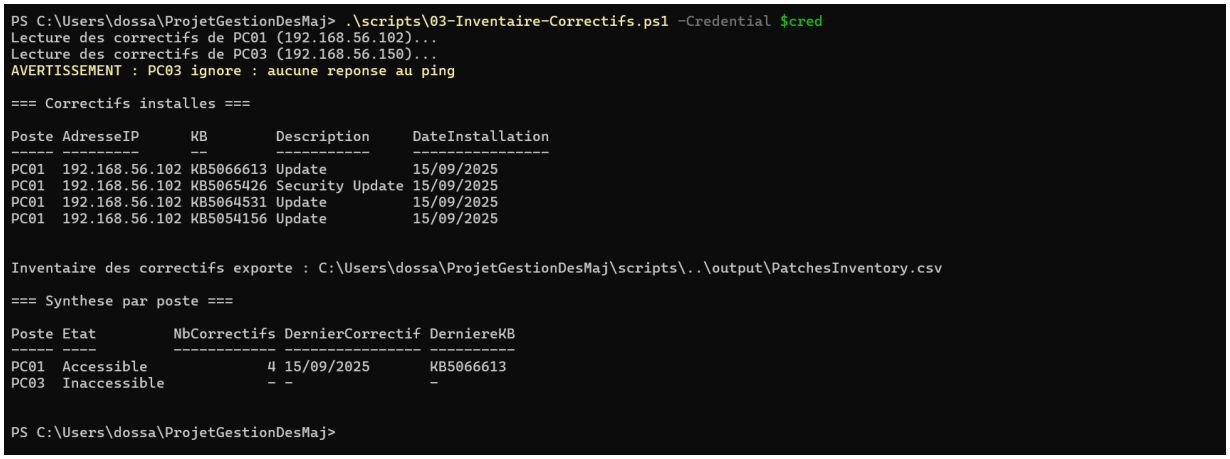


Figure 14 : *Inventaire distant des correctifs et synthèse par poste (capture 049)*

Une limite est à signaler : `Get-HotFix` ne donne que le jour d'installation. Les quatre correctifs de PC01 datant du même jour, le « dernier » est départagé par le numéro de KB le plus élevé, ce qui est un choix arbitraire mais stable.

4.3 Contrôle de conformité (partie 4)

Le fichier `config/required-patches.txt` définit la politique minimale. Le script `04-Controle-Conformite.ps1` compare, pour chaque poste, les KB installées aux KB requises. Un poste est conforme uniquement si toutes les KB requises sont présentes. Le taux global de conformité est calculé sur les postes contrôlés, les postes inaccessibles étant exclus.

Avec la politique retenue (trois KB, dont une que PC01 ne possède pas), PC01 est déclaré non conforme.

```
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\04-Controle-Conformite.ps1 -Credential $cred
Controle de conformite du 10/10/2026 01:11:37
Correctifs requis (3) : KB5065426, KB5054156, KB5124010

=== Etat de conformite ===

Poste KBRequises KBManquantes Etat         DateControle
----- ---------- ------------ ----         ------------
PC01           3            1 NON CONFORME 10/10/2026 01:11:37
PC03           3            - INACCESSIBLE 10/10/2026 01:11:37


=== Correctifs manquants ===
PC01 (192.168.56.102) : KB5124010

Rapport de conformite exporte : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\ComplianceReport.csv

Taux de conformite : 0 % (0 poste(s) conforme(s) sur 1 controle(s), hors postes inaccessibles)
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 15 : *Contrôle de conformité : poste non conforme, détail de la KB manquante et taux global (capture 051)*

En retirant temporairement cette KB de la politique, le même poste devient conforme. L'état d'un poste dépend donc entièrement de la liste, ce qui illustre la question posée par le sujet.

```
PS C:\Users\dossa\ProjetGestionDesMaj> notepad .\config\required-patches.txt
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\04-Controle-Conformite.ps1 -Credential $cred
Controle de conformite du 10/10/2026 01:15:29
Correctifs requis (2) : KB5065426, KB5054156

=== Etat de conformite ===

Poste KBRequises KBManquantes Etat         DateControle
----- ---------- ------------ ----         ------------
PC01           2            0 CONFORME     10/10/2026 01:15:29
PC03           2            - INACCESSIBLE 10/10/2026 01:15:29


Rapport de conformite exporte : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\ComplianceReport.csv

Taux de conformite : 100 % (1 poste(s) conforme(s) sur 1 controle(s), hors postes inaccessibles)
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 16 : *Contrôle de conformité : poste conforme après modification de la politique (capture 055)*

```
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\04-Controle-Conformite.ps1 -Credential $cred
Controle de conformite du 10/10/2026 01:17:21
Correctifs requis (3) : KB5065426, KB5054156, KB5124010

=== Etat de conformite ===

Poste KBRequises KBManquantes Etat         DateControle
----- ---------- ------------ ----         ------------
PC01           3            1 NON CONFORME 10/10/2026 01:17:21
PC03           3            - INACCESSIBLE 10/10/2026 01:17:21


=== Correctifs manquants ===
PC01 (192.168.56.102) : KB5124010

Rapport de conformite exporte : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\ComplianceReport.csv

Taux de conformite : 0 % (0 poste(s) conforme(s) sur 1 controle(s), hors postes inaccessibles)
PS C:\Users\dossa\ProjetGestionDesMaj> Import-Csv .\output\ComplianceReport.csv -Delimiter ";" | Format-List


Poste           : PC01
AdresseIP       : 192.168.56.102
KBRequises      : 3
KBManquantes    : 1
ListeManquantes : KB5124010
Etat            : NON CONFORME
DateControle    : 10/10/2026 01:17:21
Erreur          :

Poste           : PC03
AdresseIP       : 192.168.56.150
KBRequises      : 3
KBManquantes    : -
ListeManquantes :
Etat            : INACCESSIBLE
DateControle    : 10/10/2026 01:17:21
Erreur          : Aucune reponse au ping
```

Figure 17 : *Fichier ComplianceReport.csv (capture 056)*

Réserve : les KB de la politique ont été choisies parmi celles observées dans le lab pour obtenir un cas réaliste. Leur contenu n'a pas été vérifié dans le catalogue Microsoft. Une politique réelle se construit à partir des bulletins de sécurité, par version de Windows.

Pourquoi la politique de conformité doit-elle être régulièrement mise à jour ?

- Microsoft publie de nouveaux correctifs de sécurité chaque mois (Patch Tuesday), plus des correctifs hors cycle pour les failles exploitées activement. Une liste figée devient vite obsolète : un poste peut rester « conforme » à une politique ancienne tout en étant vulnérable aux failles publiées depuis.
- Les correctifs sont cumulatifs et se remplacent. Une KB exigée peut être remplacée par une plus récente : un poste à jour n'a alors plus l'ancienne KB et apparaîtrait à tort non conforme.
- Les KB dépendent de la version de Windows. Quand le parc évolue (nouvelle version, nouveaux postes), la liste doit suivre, sinon elle exige des correctifs qui ne s'appliquent pas à certaines machines.
- Certaines versions arrivent en fin de support et ne reçoivent plus de correctifs : la politique doit alors exiger une montée de version plutôt qu'une KB.
- La priorité dépend de la menace du moment : une faille activement exploitée justifie d'ajouter sa KB en urgence.

Dans le lab : PC01 est installé depuis une image de septembre 2025 et n'a reçu aucun correctif depuis, alors que le poste d'administration en a reçu jusqu'au 29/09/2026. Avec une politique datée de 2025, PC01 serait déclaré conforme malgré un an de retard.

Limite de notre solution : une simple liste de numéros de KB ne gère ni le remplacement d'une KB par une autre, ni la version de Windows concernée. Un outil réel (WSUS, Intune, Windows Update for Business) s'appuie sur le catalogue Microsoft pour ça.

4.4 Rapport de sécurité (partie 6)

Le script principal `PatchManager.ps1` regroupe l'ensemble : pour chaque poste, les onze informations demandées par le sujet, puis une synthèse globale de sept indicateurs et la liste des postes nécessitant une intervention.

```
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\PatchManager.ps1 -Credential $cred
Audit de PC01 (192.168.56.102)...
Audit de PC03 (192.168.56.150)...

=== Rapport de securite du 10/10/2026 01:24:33 ===

Poste AdresseIP      Accessibilite WindowsUpdate KBRequises KBManquantes Conformite
----- ---------      ------------- ------------- ---------- ------------ ----------
PC01  192.168.56.102 Accessible    Running                3            1 NON CONFORME
PC03  192.168.56.150 Inaccessible  -                      3            - INACCESSIBLE


=== Synthese globale ===


TotalPostes              : 2
PostesAccessibles        : 1
PostesInaccessibles      : 1
PostesConformes          : 0
PostesNonConformes       : 1
TotalCorrectifsManquants : 1
TauxConformite           : 0 %

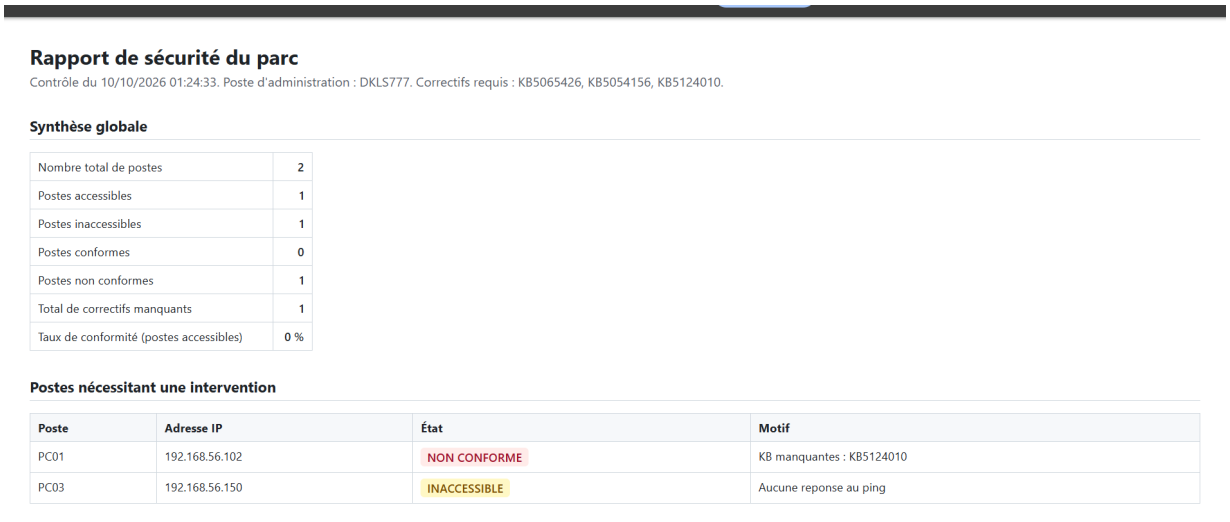


=== Postes necessitant une intervention ===
PC01 (192.168.56.102) : NON CONFORME, KB manquantes : KB5124010
PC03 (192.168.56.150) : INACCESSIBLE, Aucune reponse au ping

Rapport CSV  : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.csv
Rapport HTML : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.html
Journal      : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\PatchManager.log
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 18 : *Exécution du script principal : rapport, synthèse globale et postes à traiter (capture 057)*

Le rapport est aussi produit en HTML. Les valeurs issues des postes distants sont encodées avant d'être insérées dans la page (`HtmlEncode`), pour qu'un texte contenant du code HTML ne soit pas interprété par le navigateur.



Rapport de sécurité du parc

Contrôle du 10/10/2026 01:24:33. Poste d'administration : DKLS777. Correctifs requis : KB5065426, KB5054156, KB5124010.

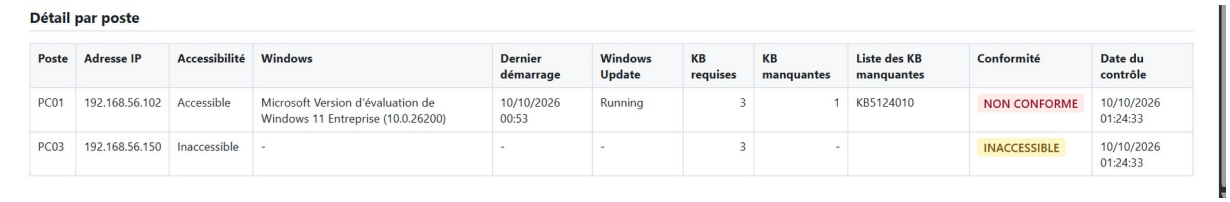
Synthèse globale

Nombre total de postes	2
Postes accessibles	1
Postes inaccessibles	1
Postes conformes	0
Postes non conformes	1
Total de correctifs manquants	1
Taux de conformité (postes accessibles)	0 %

Postes nécessitant une intervention

Poste	Adresse IP	État	Motif
PC01	192.168.56.102	NON CONFORME	KB manquantes : KB5124010
PC03	192.168.56.150	INACCESSIBLE	Aucune reponse au ping

Figure 19 : *Rapport HTML : synthèse globale et postes nécessitant une intervention (capture 058)*



Détail par poste

Poste	Adresse IP	Accessibilité	Windows	Dernier démarrage	Windows Update	KB requises	KB manquantes	Liste des KB manquantes	Conformité	Date du contrôle
PC01	192.168.56.102	Accessible	Microsoft Version d'évaluation de Windows 11 Entreprise (10.0.26200)	10/10/2026 00:53	Running	3	1	KB5124010	NON CONFORME	10/10/2026 01:24:33
PC03	192.168.56.150	Inaccessible	-	-	-	3	-		INACCESSIBLE	10/10/2026 01:24:33

Figure 20 : *Rapport HTML : détail par poste (capture 059)*

Chaque exécution ajoute ses lignes à la fin de `PatchManager.log`, sans écraser les précédentes.

```
Rapport CSV  : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.csv
Rapport HTML : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.html
Journal      : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\PatchManager.log
PS C:\Users\dossa\ProjetGestionDesMaj> Get-Content .\output\PatchManager.log
10/10/2026 01:24:33 ; Debut de l'audit
10/10/2026 01:24:42 ; PC01 ; Accessible
10/10/2026 01:24:42 ; PC01 ; Non conforme ; KB5124010
10/10/2026 01:24:46 ; PC03 ; Inaccessible ; Aucune reponse au ping
10/10/2026 01:24:46 ; Rapport genere
10/10/2026 01:24:46 ; Fin de l'audit
10/10/2026 01:30:16 ; Debut de l'audit
10/10/2026 01:30:24 ; PC01 ; Accessible
10/10/2026 01:30:24 ; PC01 ; Non conforme ; KB5124010
10/10/2026 01:30:28 ; PC03 ; Inaccessible ; Aucune reponse au ping
10/10/2026 01:30:28 ; Rapport genere
10/10/2026 01:30:28 ; Fin de l'audit
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 21 : *Journal d'exécution : deux audits successifs conservés (capture 062)*

4.5 Notification (partie 7)

Un mail n'est envoyé que si au moins un poste est NON CONFORME ou INACCESSIBLE. Son contenu suit le modèle du sujet, et le rapport HTML est joint. Les paramètres d'envoi sont dans `config/notification.psd1`, qui ne contient aucun mot de passe : si le serveur exige une authentification, les identifiants sont lus dans un fichier chiffré par Windows (DPAPI), créé par `Get-Credential | Export-Clixml`. Le serveur de test est smtp4dev, exécuté en local : il reçoit les messages sans les relayer.

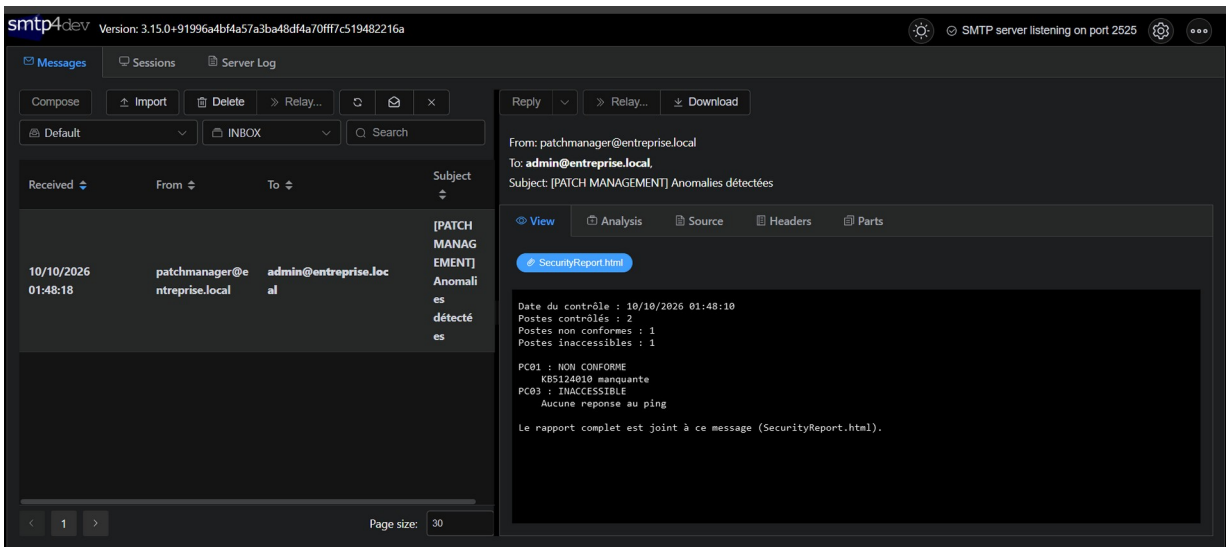


Figure 22 : *Notification reçue par l'administrateur, avec le rapport en pièce jointe (capture 068)*

Les trois comportements demandés ont été testés : envoi en cas d'anomalie, absence d'envoi sans anomalie, et gestion d'un échec d'envoi.

```
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\PatchManager.ps1 -Credential $cred -InventoryPath .\config\tests\computers-sans-anomalie.txt -RequiredPath
.\config\tests\required-sans-anomalie.txt
Audit de PC01 (192.168.56.102)...

=== Rapport de securite du 10/10/2026 01:58:30 ===

Poste AdresseIP      Accessibilite WindowsUpdate KBRequises KBManquantes Conformite
----- ---------      ------------- ------------- ---------- ------------ ----------
PC01  192.168.56.102 Accessible    Running               2            0 CONFORME


=== Synthese globale ===


TotalPostes              : 1
PostesAccessibles        : 1
PostesInaccessibles      : 0
PostesConformes          : 1
PostesNonConformes       : 0
TotalCorrectifsManquants : 0
TauxConformite           : 100 %


=== Postes necessitant une intervention ===
Aucun

Rapport CSV  : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.csv
Rapport HTML : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.html
Journal      : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\PatchManager.log
Aucune anomalie detectee : pas de notification
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 23 : *Audit sans anomalie : aucune notification n'est envoyée (capture 069)*

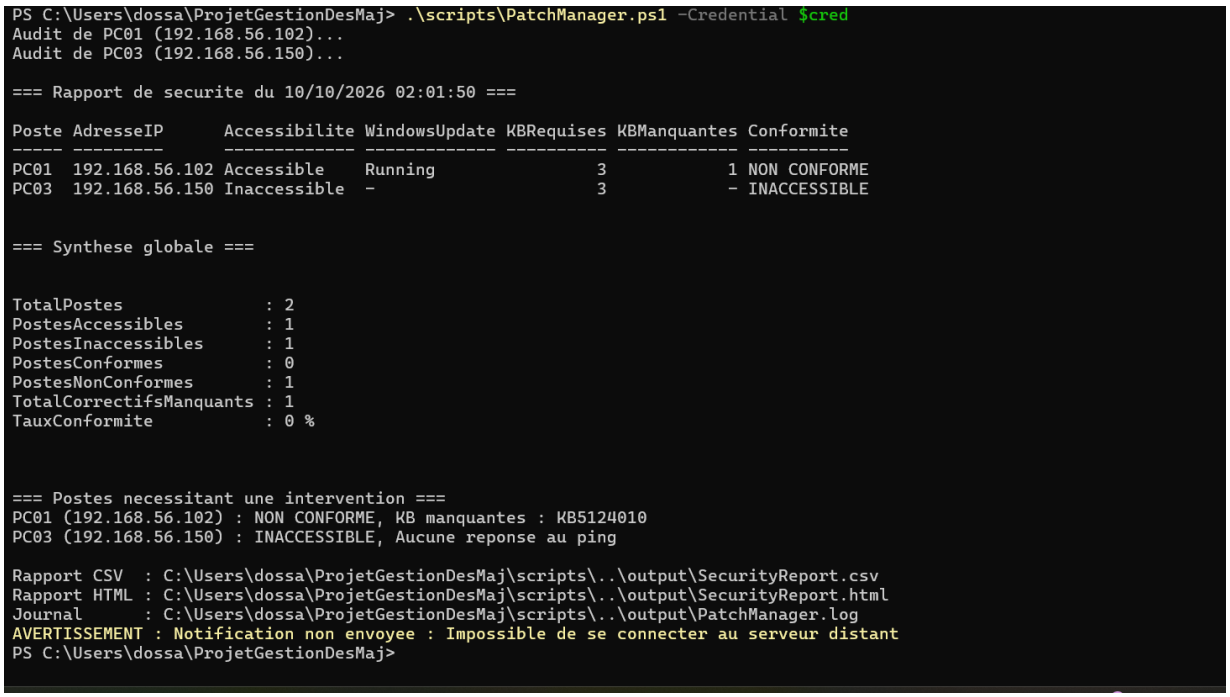


Figure 24 : *Échec d'envoi géré : le script signale l'erreur et se termine normalement (capture 071)*

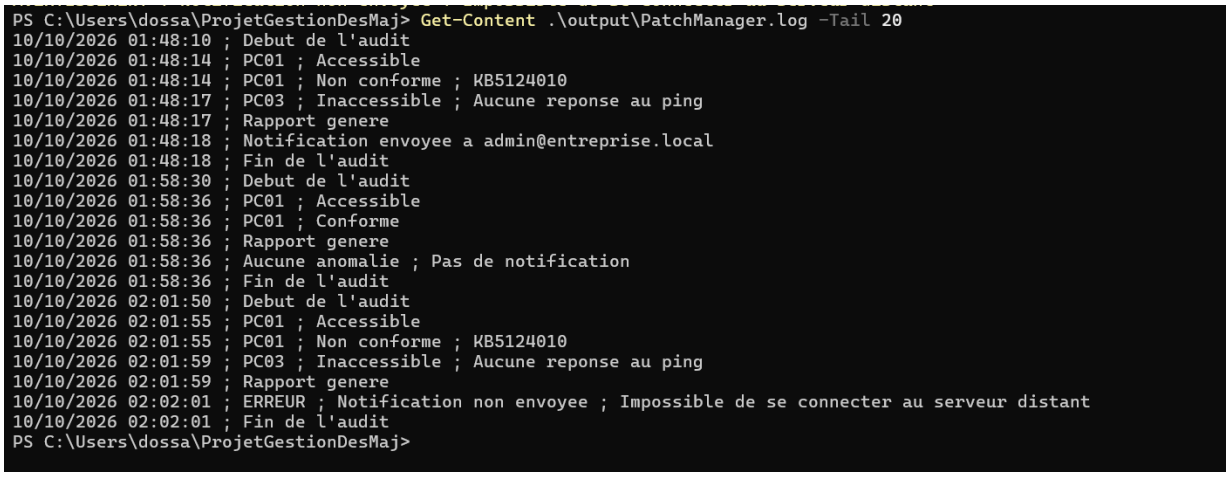


Figure 25 : *Journal : trace des trois cas de notification (capture 072)*

Quels sont les inconvénients de cette solution ?

- Dépendance à un serveur SMTP : s'il est en panne ou injoignable, l'alerte est perdue. Le script le journalise, mais personne n'est prévenu.
- Sécurité du transport : un envoi SMTP simple peut circuler en clair et sans authentification. Or le rapport joint liste les postes vulnérables et les correctifs qui leur manquent, une information précieuse pour un attaquant.
- Gestion d'un secret : si le serveur exige une authentification, il faut stocker des identifiants sur le poste d'administration. On les protège ici par un fichier chiffré (DPAPI), mais le risque existe.
- `Send-MailMessage` est une commande obsolète : elle ne gère pas l'authentification moderne (OAuth 2.0) exigée par les messageries actuelles comme Microsoft 365.
- Un mail est une alerte passive : pas d'accusé de prise en charge, pas d'escalade si personne ne réagit, pas de suivi de la résolution. Il peut finir dans les indésirables ou noyé dans la boîte de réception.
- Fatigue d'alerte : le script envoie un mail à chaque exécution tant que l'anomalie persiste, sans dédoublonnage. Lancé toutes les heures, il produirait 24 mails par jour pour le même poste.

- La notification n'existe que si le script s'exécute : si la tâche planifiée ne tourne plus, plus aucune alerte, et aucun mécanisme ne le signale.

Quelles alternatives modernes à un simple envoi SMTP depuis le script ?

- Messagerie par API avec authentification moderne : Microsoft Graph (`Send-MgUserMail`) avec OAuth 2.0 et une identité applicative, au lieu d'un mot de passe.
- Webhooks vers une messagerie d'équipe : Microsoft Teams ou Slack, un simple appel HTTPS (`Invoke-RestMethod`) qui publie l'alerte dans un canal suivi par l'équipe.
- Création automatique d'un ticket dans l'outil ITSM (GLPI, ServiceNow, Jira Service Management) par son API : l'anomalie a alors un responsable, un statut et un historique.
- Plateformes d'astreinte et d'alerte (PagerDuty, Opsgenie) : dédoublonnage, escalade, accusé de réception.
- Supervision et SIEM : écrire un événement dans le journal Windows ou envoyer en syslog, puis laisser Microsoft Sentinel, Splunk, Elastic ou Zabbix corréler et alerter.
- Outils de gestion des correctifs intégrés (Microsoft Intune, WSUS, Azure Update Manager) : ils fournissent nativement tableaux de bord de conformité et alertes, sans script maison.

5. Sécurisation de la solution (partie 8)

L'administration distante introduit ses propres risques. Cette partie les analyse puis décrit les mesures appliquées. Trois points ont été mis en œuvre au-delà de ce que demande le sujet : le compte à moindre privilège avec JEA, et le contrôle d'intégrité des rapports.

5.1 Risques liés à WinRM

- Exécution de commandes à distance : WinRM est par nature une porte d'administration. Tout compte autorisé, légitime ou volé, exécute du code sur le poste. Avant durcissement, le seul compte utilisable était `admin`, administrateur local (capture 083).
- Mouvement latéral : le poste d'administration détient des identifiants valables sur tous les postes du parc. S'il est compromis, tout le parc l'est. C'est le point le plus sensible de l'architecture.
- Authentification NTLM hors domaine (capture 096) : le client ne peut pas vérifier l'identité du serveur, d'où l'obligation de déclarer PC01 dans les TrustedHosts. Une machine qui usurpe l'adresse 192.168.56.102 recevrait la tentative d'authentification. NTLM est aussi exposé au relais et à la réutilisation du condensat du mot de passe (pass-the-hash).
- LocalAccountTokenFilterPolicy, activé par `Enable-PSRemoting` (capture 029) : les comptes locaux administrateurs gardent tous leurs privilèges à distance. Un mot de passe d'administrateur local réutilisé d'un poste à l'autre donne accès à tous.
- Transport HTTP (port 5985) : les messages sont chiffrés (`AllowUnencrypted` à false), mais sans certificat rien n'authentifie le serveur au niveau du transport.
- Exposition réseau : par défaut, la règle de pare-feu des profils Privé et Domaine acceptait toute adresse source (capture 095, avant).
- Fuite d'information : rapports, journaux et transcriptions décrivent les postes vulnérables et les correctifs manquants.
- Gestion des secrets : identifiants saisis ou stockés sur le poste d'administration, mot de passe du serveur de messagerie.

Mesures mises en œuvre : filtrage du pare-feu par adresse source (point 5), compte de service sans privilège (point 3), point de connexion JEA limité à une fonction de lecture (point 7), transcription des sessions, droits restreints sur les fichiers (point 4), aucun mot de passe dans les scripts.

5.2 Utilisateurs autorisés à ouvrir une session distante

Voir captures 083 et 086. Sur PC01, le point de connexion par défaut `microsoft.powershell` est ouvert aux membres des groupes Administrateurs et Utilisateurs de gestion à distance. Après durcissement :

Point de connexion	Qui peut s'y connecter	Ce qu'il permet
microsoft.powershell (par défaut)	`admin` uniquement (groupe Administrateurs). Le groupe Utilisateurs de gestion à distance est vide.	Session PowerShell complète, droits d'administration
PatchAudit (JEA)	`svc-patch` uniquement	Une seule fonction de lecture, `Get-PatchAudit`

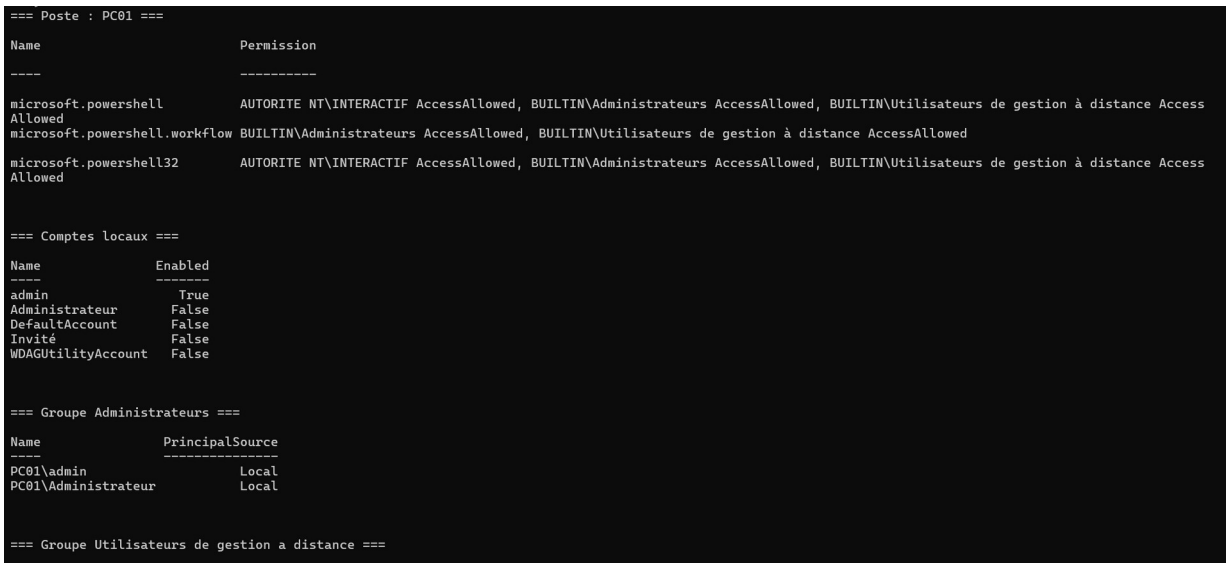


Figure 26 : *Utilisateurs autorisés à ouvrir une session distante sur PC01, avant durcissement (capture 083)*

5.3 Compte de service à moindre privilège

- Compte dédié `svc-patch`, simple utilisateur local, membre d'aucun groupe privilégié (captures 084 et 092).
- Constat : un compte non administrateur peut se connecter mais se voit refuser les lectures WMI (`Get-CimInstance`, `Get-HotFix`), car WMI réserve l'accès distant aux administrateurs (capture 085).
- Solution retenue : JEA plutôt qu'un élargissement des droits WMI. Le compte ne peut appeler qu'une fonction, exécutée par un compte virtuel temporaire (captures 087 à 091).
- Résultat : l'audit complet fonctionne sans aucun compte administrateur (capture 091), et `svc-patch` ne peut plus ouvrir de session PowerShell ordinaire (capture 093).

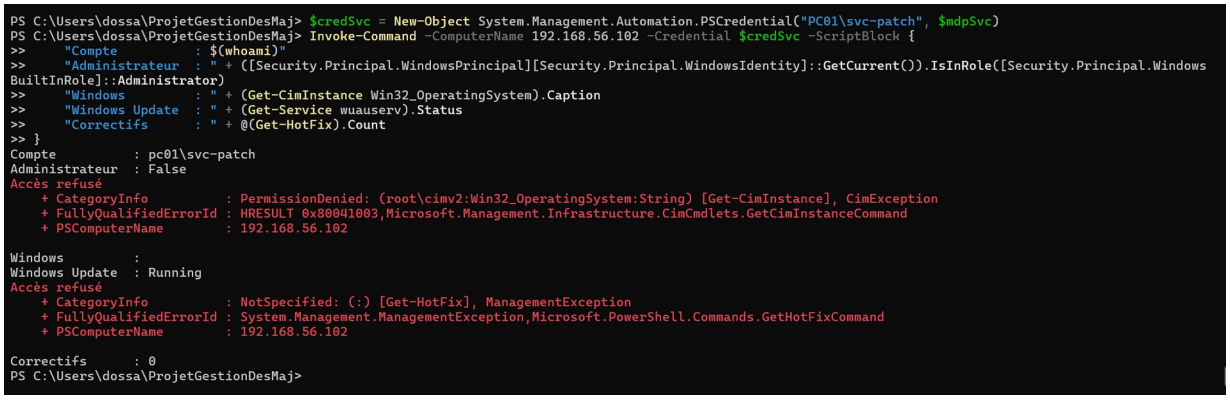


Figure 27 : *Limite d'un simple compte non administrateur : l'accès WMI à distance est refusé (capture 085)*

5.4 Just Enough Administration (JEA)

Principe : au lieu de donner à un compte une session PowerShell complète, on publie un point de connexion restreint qui n'expose que les commandes nécessaires à une tâche. JEA repose sur trois éléments :

- un fichier de rôle (`.psrc`) qui liste les commandes, fonctions et paramètres autorisés ;
- un fichier de configuration de session (`.pssc`) qui associe des utilisateurs à des rôles, fixe le mode de langage (NoLanguage : ni variables ni scripts) et l'identité d'exécution ;
- un compte virtuel temporaire : les commandes s'exécutent avec les droits nécessaires, sans que l'utilisateur les possède lui-même.

Mise en œuvre dans le projet (`scripts/jea/Install-JeaPatchAudit.ps1`) : point de connexion `PatchAudit`, accessible au seul compte `svc-patch`, exposant une unique fonction `Get-PatchAudit`. Toute autre commande est introuvable dans la session (captures 088 à 090). Chaque session est transcrite, avec l'utilisateur connecté et l'identité d'exécution (capture 094).

Bénéfice : si les identifiants de `svc-patch` sont volés, l'attaquant peut seulement lire la liste des correctifs d'un poste. Il ne peut ni installer, ni modifier, ni rebondir.

Limites : la sécurité repose sur la qualité des fonctions exposées (une fonction acceptant des paramètres mal contrôlés pourrait être détournée, d'où le choix d'une fonction sans paramètre) et le compte virtuel est administrateur local, donc le fichier de rôle doit lui-même être protégé contre toute modification.

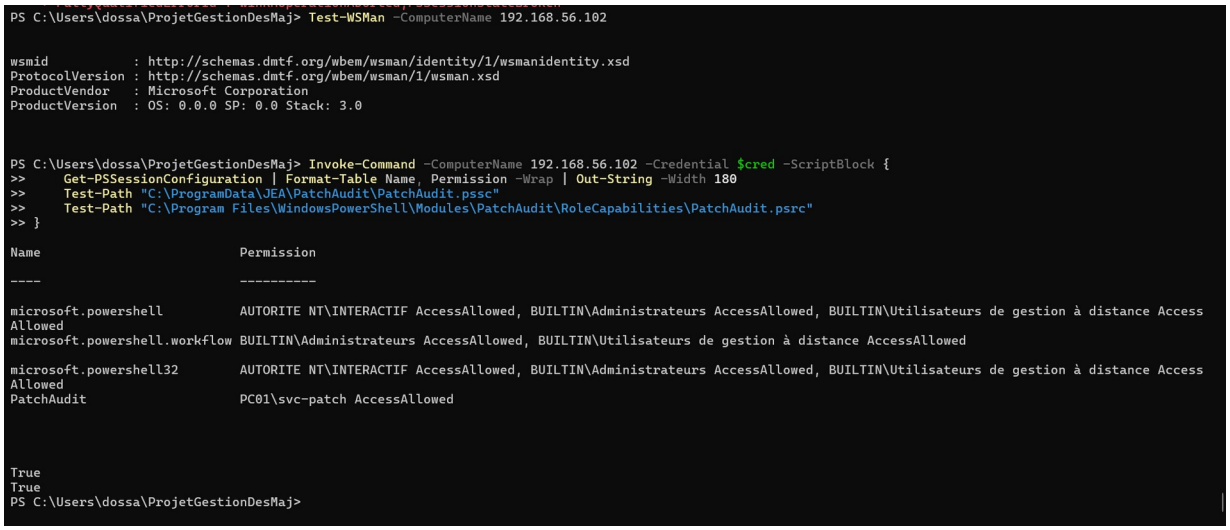


Figure 28 : *Point de connexion JEA PatchAudit enregistré, accessible au seul compte svc-patch (capture 086)*

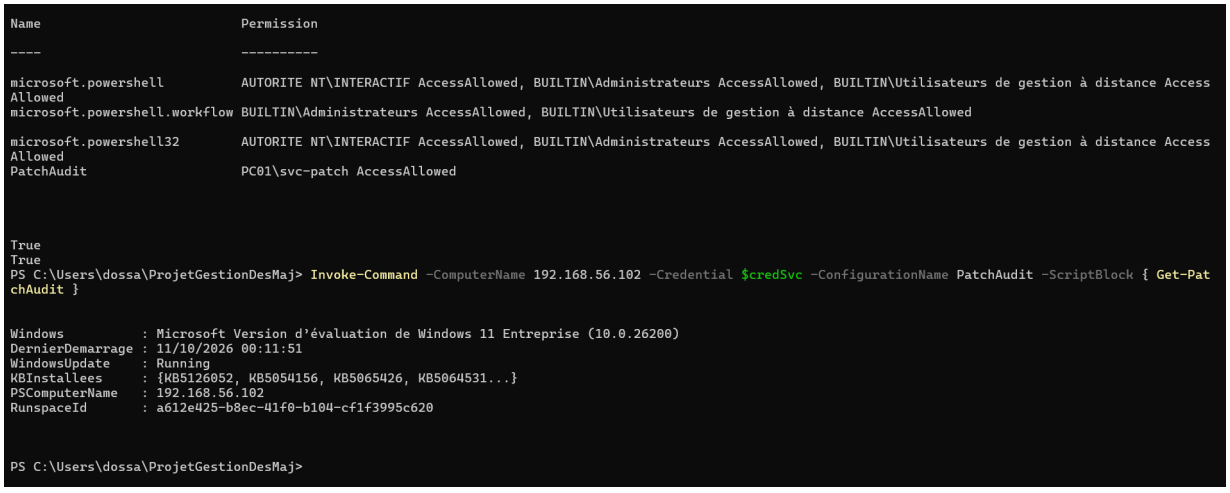


Figure 29 : *Le compte restreint obtient les informations d'audit par le point de connexion JEA (capture 087)*



Figure 30 : *Liste complète des commandes exposées par le point de connexion JEA (capture 090)*

```
True
PS C:\Users\dossa\ProjetGestionDesMaj> Invoke-Command -ComputerName 192.168.56.102 -Credential $credSvc -ConfigurationName PatchAudit -ScriptBlock { Get-Pat
chAudit }


Windows          : Microsoft Version d'évaluation de Windows 11 Entreprise (10.0.26200)
DernierDemarrage : 11/10/2026 00:11:51
WindowsUpdate    : Running
KBInstallees     : {KB5126052, KB5054156, KB5065426, KB5064531...}
PSComputerName   : 192.168.56.102
RunspaceId       : a612e425-b8ec-41f0-b104-cf1f3995c620



PS C:\Users\dossa\ProjetGestionDesMaj> Invoke-Command -ComputerName 192.168.56.102 -Credential $credSvc -ConfigurationName PatchAudit -ScriptBlock { Get-Pro
cess }
Le terme «Get-Process» n'est pas reconnu comme nom d'applet de commande, fonction, fichier de script ou programme exécutable. Vérifiez l'orthographe du
nom, ou si un chemin d'accès existe, vérifiez que le chemin d'accès est correct et réessayez.
    + CategoryInfo          : ObjectNotFound: (Get-Process:String) [], CommandNotFoundException
    + FullyQualifiedErrorId : CommandNotFoundException
    + PSComputerName        : 192.168.56.102

PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 31 : *Une commande non autorisée n'existe pas dans la session JEA (capture 088)*

```
PS C:\Users\dossa\ProjetGestionDesMaj> .\scripts\PatchManager.ps1 -Credential $credSvc -ConfigurationName PatchAudit -SansNotification
Audit de PC01 (192.168.56.102)...
Audit de PC03 (192.168.56.150)...

=== Rapport de securite du 11/10/2026 00:40:03 ===

Poste AdresseIP      Accessibilite WindowsUpdate KBRequises KBManquantes Conformite
----- ---------      ------------- ------------- ---------- ------------ ----------
PC01  192.168.56.102 Accessible    Running                3            1 NON CONFORME
PC03  192.168.56.150 Inaccessible  -                      3            - INACCESSIBLE


=== Synthese globale ===


TotalPostes              : 2
PostesAccessibles        : 1
PostesInaccessibles      : 1
PostesConformes          : 0
PostesNonConformes       : 1
TotalCorrectifsManquants : 1
TauxConformite           : 0 %



=== Postes necessitant une intervention ===
PC01 (192.168.56.102) : NON CONFORME, KB manquantes : KB5124010
PC03 (192.168.56.150) : INACCESSIBLE, Aucune reponse au ping

Rapport CSV  : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.csv
Rapport HTML : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\SecurityReport.html
Journal      : C:\Users\dossa\ProjetGestionDesMaj\scripts\..\output\PatchManager.log
Notification desactivee (-SansNotification)
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 32 : *Audit complet réalisé avec le compte svc-patch à travers JEA (capture 091)*

```
PS C:\Users\dossa\ProjetGestionDesMaj> Invoke-Command -ComputerName 192.168.56.102 -Credential $credSvc -ScriptBlock { hostname }
[192.168.56.102] La connexion au serveur distant 192.168.56.102 a échoué avec le message d'erreur suivant: Accès refusé. Pour plus d'informations, voir la
rubrique d'aide about_Remote_Troubleshooting.
    + CategoryInfo          : OpenError: (192.168.56.102:String) [], PSRemotingTransportException
    + FullyQualifiedErrorId : AccessDenied,PSSessionStateBroken
PS C:\Users\dossa\ProjetGestionDesMaj> Invoke-Command -ComputerName 192.168.56.102 -Credential $credSvc -ConfigurationName PatchAudit -ScriptBlock { Get-Pat
chAudit }


Windows          : Microsoft Version d'évaluation de Windows 11 Entreprise (10.0.26200)
DernierDemarrage : 11/10/2026 00:11:51
WindowsUpdate    : Stopped
KBInstallees     : {KB5126052, KB5054156, KB5065426, KB5064531...}
PSComputerName   : 192.168.56.102
RunspaceId       : 63de88a6-867a-4fb5-9cee-4b84d978b3f0



PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 33 : *Le compte de service ne peut plus se connecter qu'au point de connexion JEA (capture 093)*

```
PS C:\Users\dossa\ProjetGestionDesMaj> Invoke-Command -ComputerName 192.168.56.102 -Credential $cred -ScriptBlock {
>>     Get-ChildItem "C:\ProgramData\JEA\PatchAudit\Transcripts" | Sort-Object LastWriteTime | Select-Object -Last 1 | Get-Content -TotalCount 30
>> }
**********************
Début de la transcription Windows PowerShell
Heure de début : 20261011004237
Nom d'utilisateur : PC01\svc-patch
Utilisateur runAs :  WinRM Virtual Users\WinRM VA_6_PC01_svc-patch
Nom de la configuration : PatchAudit
Ordinateur : PC01 (Microsoft Windows NT 10.0.26200.0)
Application hôte : C:\WINDOWS\system32\wsmprovhost.exe -Embedding
ID de processus : 8712
PSVersion: 5.1.26100.6584
PSEdition: Desktop
PSCompatibleVersions: 1.0, 2.0, 3.0, 4.0, 5.0, 5.1.26100.6584
BuildVersion: 10.0.26100.6584
CLRVersion: 4.0.30319.42000
WSManStackVersion: 3.0
PSRemotingProtocolVersion: 2.3
SerializationVersion: 1.1.0.1
**********************
PS>CommandInvocation (Get-PatchAudit) : « Get-PatchAudit »

Windows                                                    DernierDemarrage    WindowsUpdate KBInstallees
-------                                                    ----------------    ------------- ------------
Microsoft Version d'évaluation de Windows 11 Entreprise (10.0.26200) 11/10/2026 00:11:51 Stopped       {KB5126052, KB5054156, KB5065426, KB5064531...}


**********************
Fin de la transcription Windows PowerShell
Heure de fin : 20261011004240
**********************
PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 34 : *Transcription d'une session JEA : qui s'est connecté, sous quelle identité, quelle commande (capture 094)*

5.5 Accès aux fichiers produits

- Dossier `output` du poste d'administration : accès limité au compte de l'administrateur, à Système et au groupe Administrateurs. Les droits étaient déjà corrects par héritage du profil utilisateur, ils ont été rendus explicites pour ne plus dépendre de l'emplacement du dossier (capture 097).
- Transcriptions JEA sur PC01 : accès limité à Système et aux Administrateurs.
- Le dossier `output` et les fichiers `*.log` sont exclus du dépôt Git par `.gitignore`. Seuls des exemples sont versionnés, dans un dépôt privé.



Figure 35 : *Droits NTFS du dossier des rapports sur le poste d'administration (capture 097)*

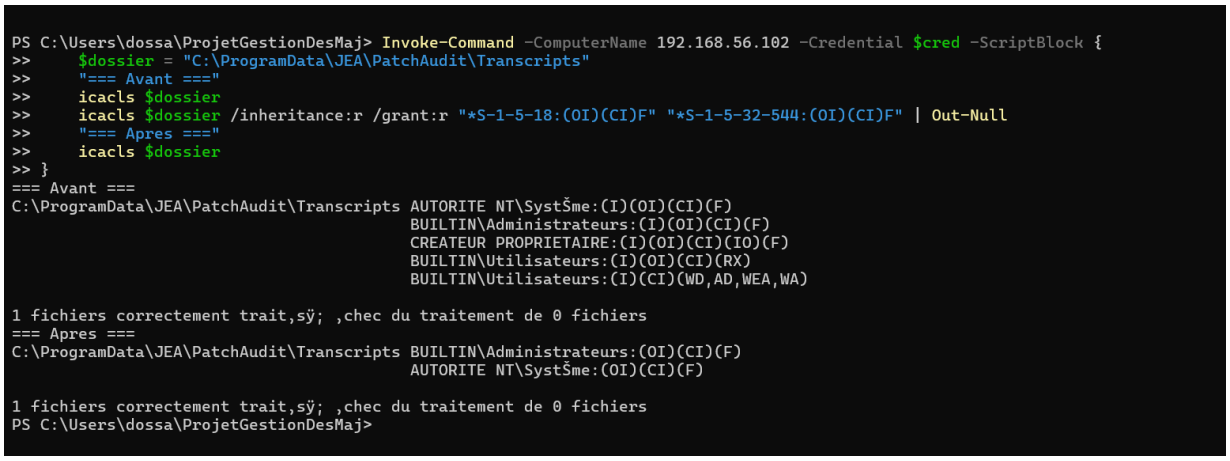


Figure 36 : *Restriction des droits sur les transcriptions JEA de PC01 (capture 098)*

5.6 Règles de pare-feu WinRM

Voir capture 095. Deux règles entrantes autorisent le port TCP 5985 sur PC01 : `WINRM-HTTP-In-TCP` (profil Public) et `WINRM-HTTP-In-TCP-NoScope` (profils Domaine et Privé). Les deux sont désormais limitées à l'adresse distante 192.168.56.1, celle du poste d'administration. Aucune autre machine ne peut atteindre le service, quel que soit le profil réseau actif.

Limite : une adresse IP peut être usurpée sur un même réseau local. Le filtrage réduit la surface d'attaque, il ne remplace pas l'authentification.

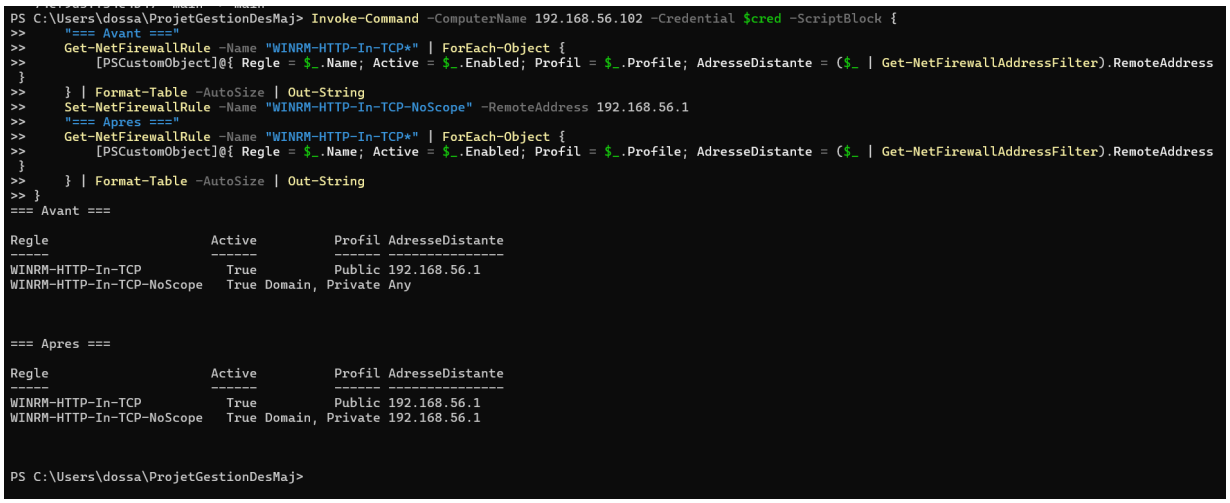


Figure 37 : *Les deux règles de pare-feu WinRM n'acceptent plus que le poste d'administration (capture 095)*

5.7 Mode d'authentification

Mode utilisé dans le lab : NTLM, négocié par le mode Negotiate (capture 096). Basic, Certificate et CredSSP sont désactivés côté service.

Kerberos est préférable dès que les machines appartiennent à un domaine Active Directory et que l'on se connecte par nom de machine :

- Authentification mutuelle : le client vérifie l'identité du serveur grâce au ticket délivré par le contrôleur de domaine. Plus besoin de TrustedHosts, et une machine usurpatrice est détectée.
- Le mot de passe et son condensat ne circulent jamais vers le serveur : le client présente un ticket à durée de vie limitée. Les attaques par relais NTLM et pass-the-hash ne s'appliquent pas de la même façon.
- Gestion centralisée : comptes, groupes et délégation sont administrés dans l'annuaire, et non poste par poste.

Kerberos n'est pas utilisable dans notre lab : pas de domaine, et connexion par adresse IP. Hors domaine, l'alternative pour authentifier le serveur est WinRM sur HTTPS (port 5986) avec un certificat.

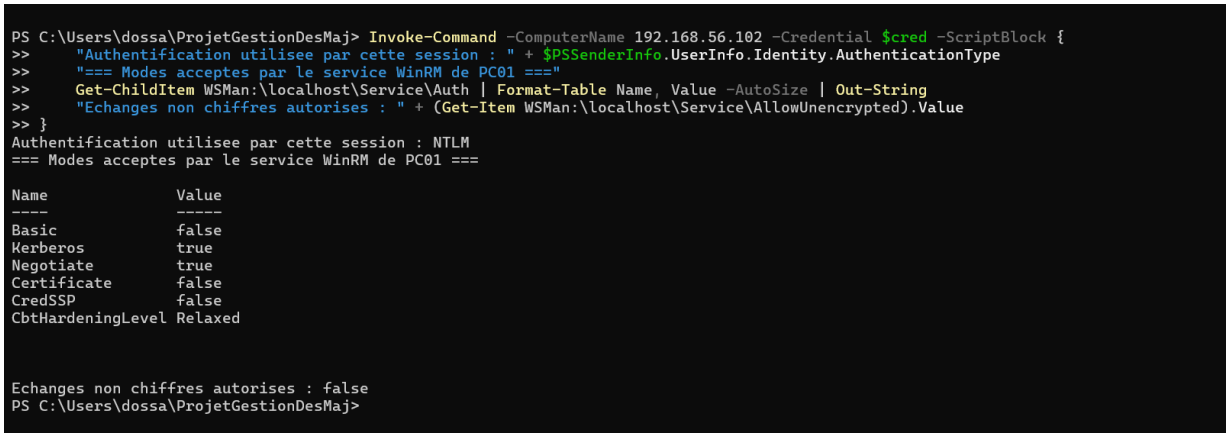


Figure 38 : *Mode d'authentification utilisé et modes acceptés par le service WinRM (capture 096)*

5.8 Conservation des rapports et des journaux

La stratégie comporte une partie mise en œuvre dans `PatchManager.ps1` et une partie proposée, qui dépend d'une infrastructure absente du lab.

Mis en œuvre dans le projet :

Risque	Mesure	Preuve
Modification non autorisée	À chaque audit, copie datée des rapports dans `output/archives/<date>/`, passée en lecture seule, et empreinte SHA-256 enregistrée dans `empreintes.csv` et dans le journal. `Test-IntegriteRapports.ps1` recalcule les empreintes et signale tout fichier altéré ou absent.	Captures 100, 102 et 103
Modification non autorisée	L'empreinte du rapport est aussi écrite dans le mail de notification : une copie de référence existe hors du poste d'administration.	Code de `PatchManager.ps1`
Suppression	Chaque audit laisse sa propre archive, l'historique ne dépend plus d'un fichier unique écrasé à chaque exécution.	Capture 100
Croissance sans limite	Rotation du journal au-delà d'une taille maximale (`-TailleMaxJournalKo`), et suppression des archives plus anciennes que la durée de conservation (`-RetentionJours`, 365 jours par défaut).	Code de `PatchManager.ps1`, non déclenché dans le lab
Exposition d'informations	Droits NTFS limités à l'administrateur, Système et Administrateurs sur `output` (les archives en héritent), transcriptions JEA limitées à Système et Administrateurs, dossier `output` exclu du dépôt Git, dépôt privé, aucun secret dans les journaux.	Captures 097 et 098

Proposé, non mis en œuvre :

- Centralisation des journaux vers un serveur dédié ou un SIEM, qui en reçoit une copie que le poste d'administration ne peut plus modifier. C'est la vraie protection contre un attaquant devenu administrateur du poste : dans notre solution, il pourrait réécrire à la fois un rapport et son empreinte locale.
- Sauvegarde sur un support distinct, selon la règle 3-2-1 (trois copies, deux supports, une hors site), et stockage en écriture unique (WORM) pour les journaux.
- Chiffrement du disque du poste d'administration (BitLocker) et chiffrement du transport pour tout envoi de rapport.
- Signature numérique des rapports par un certificat, plus forte qu'une simple empreinte.

Limite assumée : l'attribut lecture seule et l'empreinte locale détectent une modification accidentelle ou maladroite, pas un attaquant disposant des droits d'administration sur le poste.

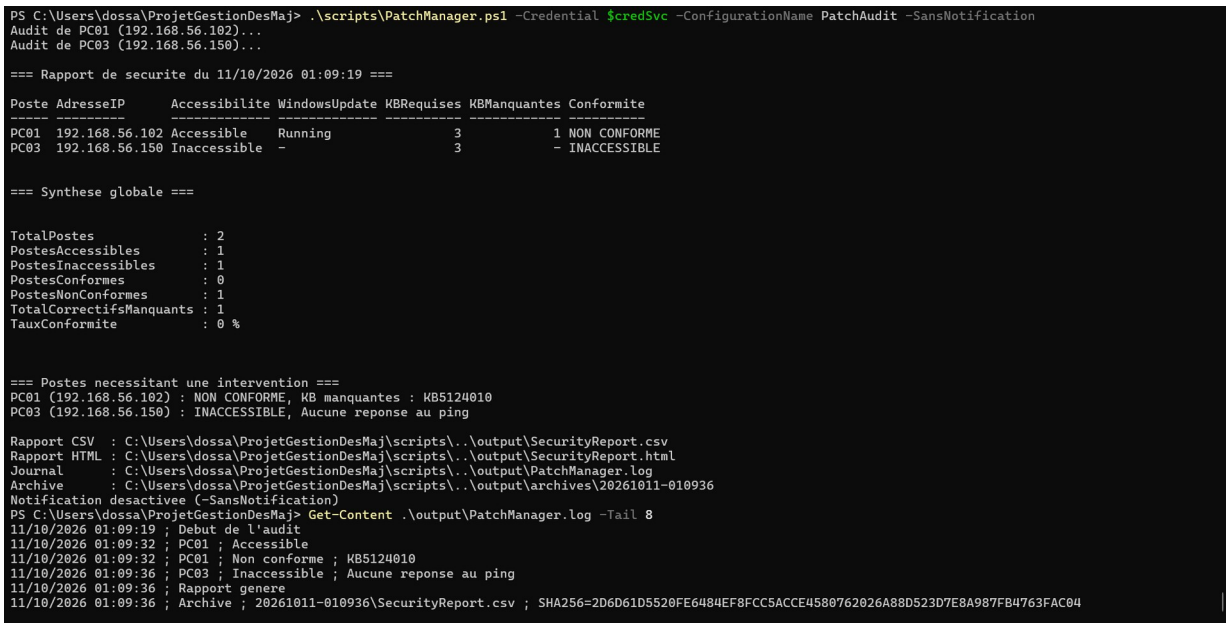


Figure 39 : *Archivage daté des rapports et enregistrement de leur empreinte SHA-256 dans le journal (capture 100)*

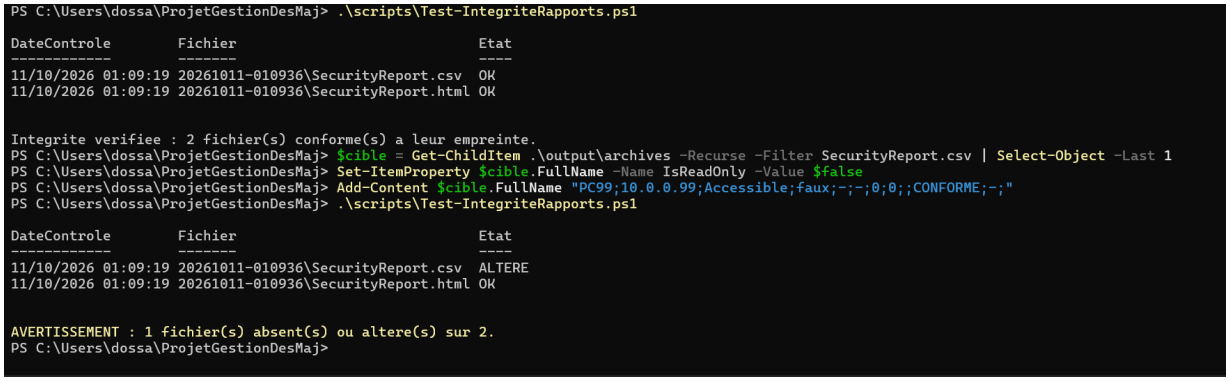


Figure 40 : *Détection d'un rapport archivé modifié après coup (capture 103)*

6. Choix techniques

Sujet	Choix retenu	Raison
Hyperviseur	VirtualBox, réseau privé hôte	Adresses stables entre l'hôte et la VM, indépendantes du Wi-Fi
Parc de test	Un poste réel et un poste fictif	Autorisé par le sujet, permet de tester le cas inaccessible sans VM supplémentaire
Organisation du code	Un script par partie, un script principal, des fonctions communes	Chaque partie du sujet reste démontrable seule, sans dupliquer la lecture des fichiers
Collecte	`Get-CimInstance`, `Get-HotFix`, `Get-Service` par `Invoke-Command`	Commandes natives de PowerShell 5.1, aucun module à installer
Robustesse	Ping préalable, `try/catch`, `-ErrorAction Stop`	Le script continue quand un poste est injoignable et enregistre la cause
Données	Objets `PSCustomObject`, export CSV avec séparateur point-virgule	Tri et export simples, ouverture directe dans Excel en français
Identifiants	`PSCredential`, `SecureString`, fichier DPAPI	Aucun secret en clair dans les scripts, la configuration ou l'historique
Moindre privilège	JEA plutôt que des droits WMI élargis	Le compte de service ne peut appeler qu'une fonction de lecture
Pare-feu	Filtrage par adresse source sur les deux règles WinRM	Indépendant du profil réseau, qui s'est révélé instable
Intégrité	Archive datée, lecture seule, empreinte SHA-256	Détecte une modification après coup
Encodage	Scripts en ASCII, accents du HTML en entités	Évite les erreurs d'encodage de PowerShell 5.1

7. Tests effectués et résultats

Test	Résultat attendu	Résultat obtenu	Capture
Ping de PC01 avant ouverture du pare-feu	Échec	Échec	025
Ping de PC01 après ouverture	Réussite	Réussite	027
Disponibilité du parc	PC01 accessible, PC03 inaccessible	Conforme à l'attendu	028
Session distante et `Invoke-Command`	Commandes exécutées sur PC01	Conforme à l'attendu	033, 035
Inventaire avec WinRM bloqué par le pare-feu	Le script continue et enregistre l'erreur	Conforme à l'attendu	038, 039
Inventaire après correction	PC01 renseigné, PC03 avec sa cause	Conforme à l'attendu	042, 043
Persistance après redémarrage de PC01	Accès WinRM conservé	Conforme à l'attendu	047
Inventaire des correctifs	4 correctifs pour PC01, PC03 ignoré	Conforme à l'attendu	049
Conformité avec 3 KB requises	PC01 non conforme, taux 0 %	Conforme à l'attendu	051
Conformité avec 2 KB requises	PC01 conforme, taux 100 %	Conforme à l'attendu	055
Rapport HTML	Synthèse, postes à traiter, détail	Conforme à l'attendu	058, 059
Journal sur deux audits	Historique conservé	Conforme à l'attendu	062
Notification avec anomalies	Mail reçu avec pièce jointe	Conforme à l'attendu	068
Notification sans anomalie	Aucun mail	Conforme à l'attendu	069, 070
Notification, serveur SMTP arrêté	Erreur journalisée, script terminé	Conforme à l'attendu	071, 072
Compte non administrateur, point de connexion par défaut	Lecture WMI refusée	Refusée	085
Compte de service par JEA	Audit complet	Conforme à l'attendu	087, 091
Commande non autorisée par JEA	Commande introuvable	Introuvable	088, 089
Compte de service, session ordinaire	Accès refusé	Refusé	093
Contrôle d'intégrité, rapports intacts	OK	OK	102
Contrôle d'intégrité, rapport falsifié	ALTERE	ALTERE	103

Deux fonctions sont écrites mais n'ont pas été déclenchées dans le lab : la rotation du journal au-delà de 1024 Ko et la suppression des archives de plus de 365 jours.

8. Difficultés rencontrées

8.1 La machine virtuelle ne démarrait pas

Après sa création, PC01 est restée sur un écran noir et son disque virtuel pesait 0 Go : Windows ne s'était jamais installé. Le journal de VirtualBox contenait la ligne `Attempting fall back to NEM: VT-x is not available`. L'hyperviseur Hyper-V était actif sur l'hôte, et dans ce mode le micrologiciel UEFI de la VM se figeait avant d'atteindre l'image d'installation. La désactivation de l'hyperviseur (`bcdedit /set hypervisorlaunchtype off`) puis un redémarrage de l'hôte ont réglé le problème.

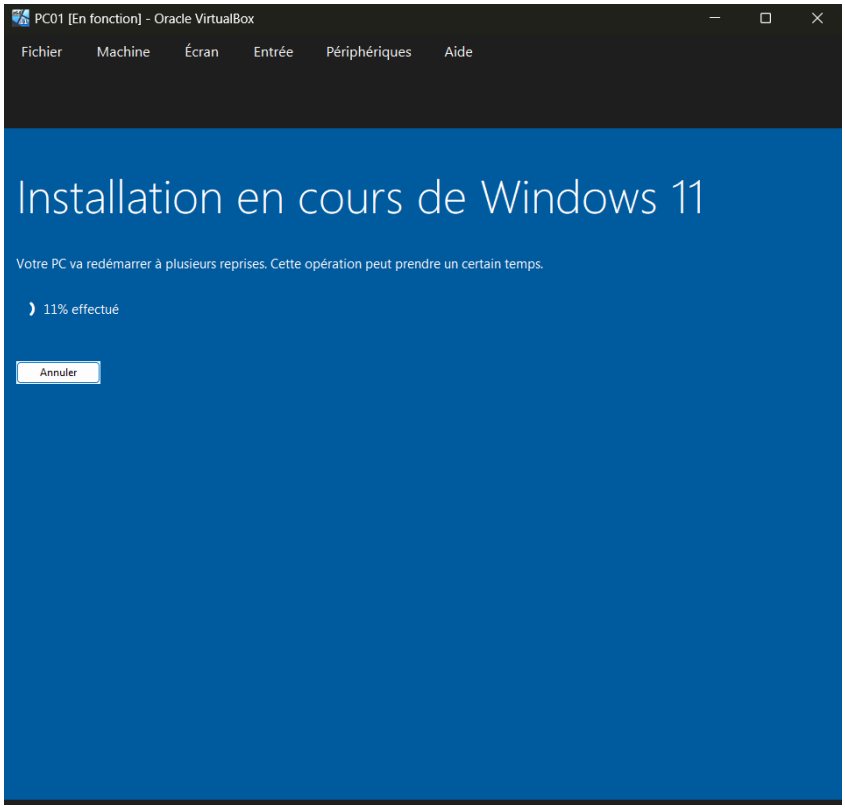


Figure 41 : *Installation de Windows 11 sur PC01 après résolution du conflit avec Hyper-V (capture 018)*

8.2 WinRM bloqué quelques heures après sa mise en service

L'accès distant fonctionnait, puis le premier inventaire a échoué avec un message évoquant l'exception de pare-feu. Le diagnostic a montré que l'interface était repassée en profil Public, et que `Enable-PSRemoting` n'avait ouvert WinRM que pour les profils Privé et Domaine. Plutôt que de repasser le réseau en Privé, réglage qui ne tenait pas, la règle du profil Public a été activée et limitée à l'adresse du poste d'administration.

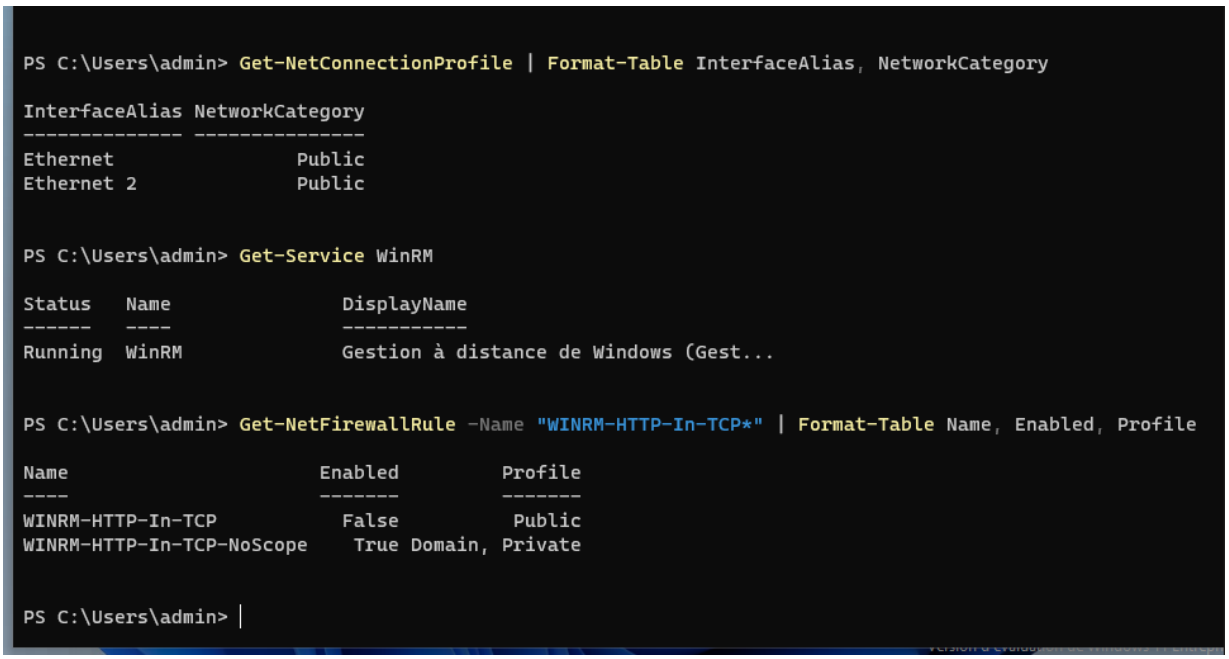


Figure 42 : *Diagnostic : le pare-feu bloque WinRM car l'interface est repassée en profil Public (capture 040)*

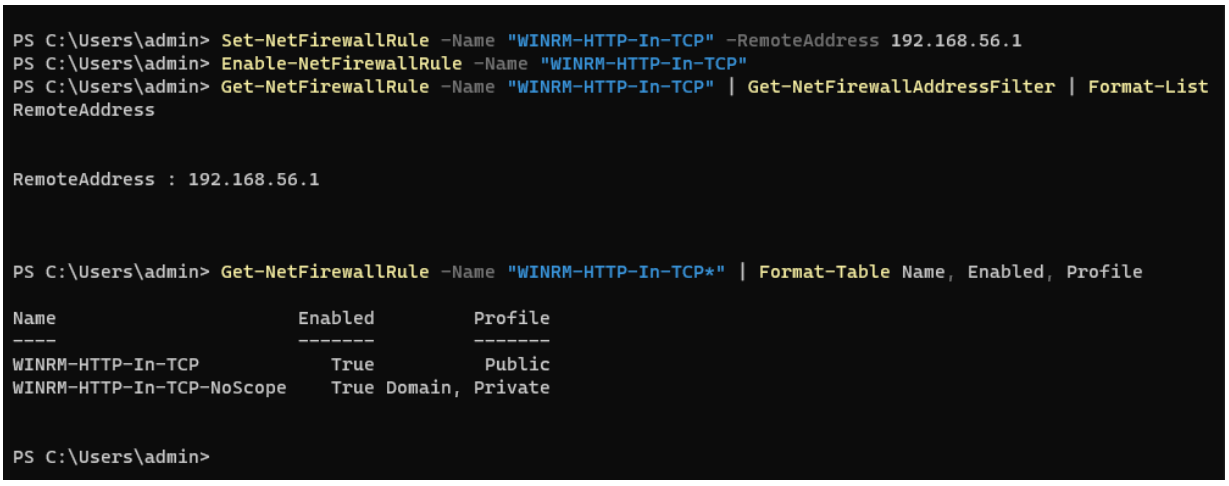


Figure 43 : *Ouverture de WinRM sur le profil Public, restreinte au seul poste d'administration (capture 041)*

8.3 Une date de dernier démarrage inattendue

L'inventaire affichait une date de démarrage antérieure au dernier arrêt de la VM. Après vérification du fuseau et de l'horloge, l'explication retenue est le démarrage rapide de Windows : un arrêt suivi d'un démarrage met le noyau en hibernation, et la date n'est pas réinitialisée. Un vrai redémarrage a mis la date à jour. Ce comportement a un intérêt direct pour le Patch Management : « éteindre puis rallumer » n'applique pas les correctifs en attente de redémarrage.

8.4 Saturation du disque de l'hôte

En pleine séance, le serveur de messagerie de test a refusé de démarrer avec une erreur d'entrée-sortie. La cause réelle était ailleurs : le disque de l'hôte était passé de 54,8 Go libres à 0. PC01, installée depuis une image de 2025, téléchargeait un an de mises à jour, et l'instantané VirtualBox obligeait à conserver l'ancien état du disque en plus du nouveau (18 Go, plus 28 Go de différences). VirtualBox a mis la VM en pause de lui-même. La suppression de l'instantané a fusionné les disques (32 Go au total) et Windows Update a été suspendu sur PC01.

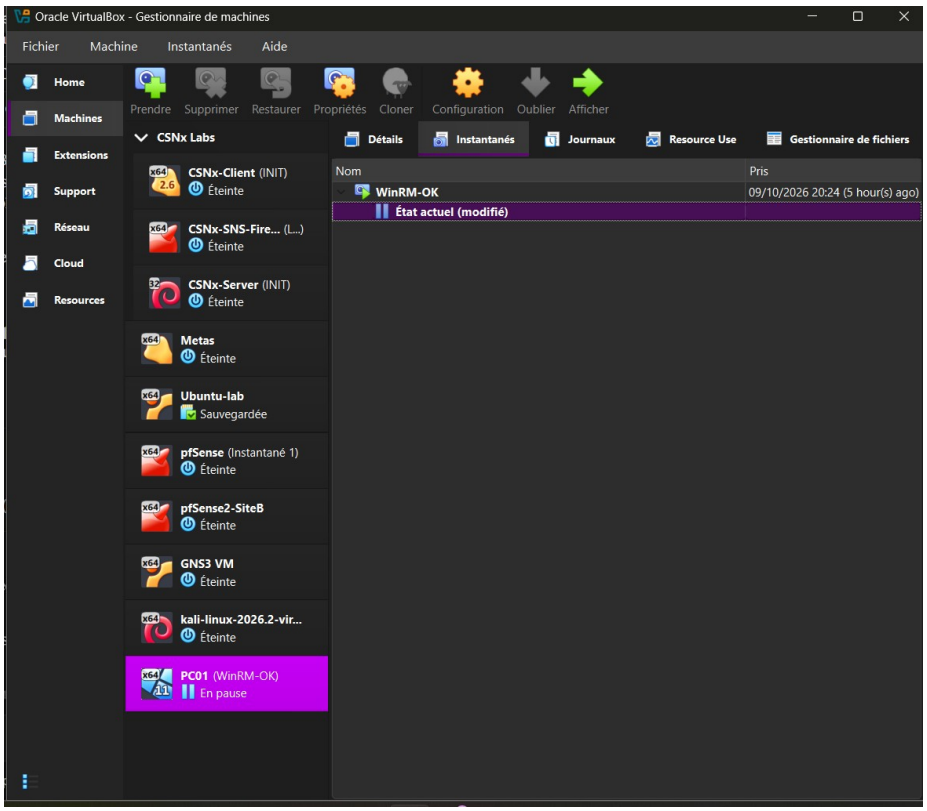


Figure 44 : *VM suspendue automatiquement par VirtualBox à la saturation du disque de l'hôte (capture 073)*

```
PS C:\Users\dossa\ProjetGestionDesMaj> Get-ChildItem "$HOME\VirtualBox VMs\PC01" -Recurse -File | Sort-Object Length -Descending | Select-Object -First 4 Name, @{n='Go';e={[math]::Round($_.Length/1GB,2)}}

Name                 Go
----                 --
PC01.vdi          32,26
VBoxHardening.log     0
PC01.nvram            0
VBox.log              0


PS C:\Users\dossa\ProjetGestionDesMaj> Get-PSDrive C | Format-Table Name, @{n='LibreGo';e={[math]::Round($_.Free/1GB,1)}}

Name LibreGo
---- -------
C       48,8


PS C:\Users\dossa\ProjetGestionDesMaj>
```

Figure 45 : *Après fusion de l'instantané : un seul disque de 32 Go et 48,8 Go libres (capture 076)*

8.5 Le moindre privilège ne se résume pas à retirer des droits

Le compte de service non administrateur pouvait se connecter, mais WMI lui refusait toute lecture à distance. C'est cette difficulté qui a conduit à mettre en œuvre JEA, décrit en section 5.

8.6 Enseignements

- Lire les journaux avant de multiplier les essais : le journal de VirtualBox a donné la cause en une ligne.
- Une erreur de transport ne dit rien du résultat de l'opération distante : lors de l'installation de JEA, la session a été coupée alors que l'installation avait réussi.
- Vérifier les ressources de base (espace disque) avant de soupçonner un logiciel.
- Un réglage qui fonctionne doit être testé après un redémarrage.

9. Limites et perspectives

9.1 Limites de la solution

- Un poste dont le pare-feu bloque le ping est considéré comme inaccessible, même si WinRM répond.
- La politique est une simple liste de numéros de KB : elle ne gère ni le remplacement d'une KB par une plus récente, ni la version de Windows concernée.
- Les postes sont interrogés l'un après l'autre. Un audit de deux postes dure environ 13 secondes, dont 4 à attendre le poste injoignable.
- L'authentification repose sur NTLM, faute de domaine Active Directory.
- Les empreintes sont conservées sur le même poste que les rapports : elles détectent une modification maladroite, pas un attaquant administrateur du poste.
- Le lab ne comporte qu'un seul poste supervisé réel.
- `Send-MailMessage` est une commande obsolète, sans authentification moderne.

9.2 Perspectives

- Interroger les postes en parallèle (`Invoke-Command` accepte une liste de machines).
- S'appuyer sur le catalogue Microsoft, ou sur WSUS, pour connaître les correctifs réellement applicables à chaque version.
- Intégrer un domaine Active Directory pour bénéficier de Kerberos, ou passer WinRM en HTTPS avec des certificats.
- Centraliser les journaux dans un SIEM et remplacer le mail par un webhook ou la création d'un ticket.
- Planifier l'audit par une tâche planifiée exécutée sous le compte de service.

10. Conclusion

Le projet aboutit à une solution fonctionnelle qui couvre toute la chaîne demandée : inventaire, collecte distante, contrôle de conformité, rapport, journalisation et notification. Chaque fonction a été testée sur le lab, y compris dans ses cas d'erreur, et chaque test est documenté par une capture.

Le travail le plus formateur a été la sécurisation. Partir d'un outil qui fonctionne avec un compte administrateur, puis lui retirer ses droits un à un jusqu'à ce qu'un compte de service ne puisse plus appeler qu'une seule fonction de lecture, montre concrètement ce que signifie le moindre privilège, et pourquoi il demande plus de travail que de simplement retirer un groupe.

Les difficultés rencontrées relèvent presque toutes de l'environnement plutôt que du code : conflit d'hyperviseurs, profils de pare-feu, démarrage rapide, saturation du disque. Elles rappellent qu'un outil d'administration vaut autant par sa capacité à expliquer ses échecs que par son fonctionnement nominal.